



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

Technische Richtlinie TR-03185: Sicherer Software-Lebenszyklus

Version 1.0, Datum 06.08.2024



Änderungshistorie

Tabelle 1 Historie

Version	Datum	Name	Beschreibung
1.0	06.08.2024		Version zur Erstveröffentlichung

Bundesamt für Sicherheit in der Informationstechnik
Postfach 20 03 63
53133 Bonn
Internet: <https://www.bsi.bund.de>
© Bundesamt für Sicherheit in der Informationstechnik 2024

Inhalt

1	Einleitung.....	6
2	Aufbau der TR.....	7
2.1	Begriffsfestlegung.....	7
2.2	Hinweise und Erläuterungen.....	8
3	Anforderungen an den Hersteller.....	10
3.1	Anforderungen an den Hersteller als Anwender von Software.....	10
3.1.1	Projektmanagement.....	10
3.1.2	Dokumentation.....	15
3.1.3	Test und Freigabe.....	15
3.1.4	Installation.....	18
3.1.5	Patch- und Änderungsmanagement.....	19
3.1.6	Außerbetriebnahme.....	21
3.2	Anforderungen an den Hersteller als Software-Produzent.....	21
3.2.1	Projektmanagement.....	22
3.2.2	Dokumentation.....	25
3.2.3	Entwicklung.....	26
3.2.4	Test und Freigabe.....	35
3.2.5	Auslieferung.....	38
3.2.6	Schwachstellenmanagement.....	38
3.2.7	Außerbetriebnahme.....	41
	Glossar.....	43
	Literaturverzeichnis.....	45

Abbildungsverzeichnis

Abbildung 1: Perspektiven und Prozesse beim Hersteller.....	11
---	----

Tabellenverzeichnis

Tabelle 1 Historie.....	2
Tabelle 2 Systematik der Anforderungen.....	10
Tabelle 3 Anforderungen Anwender Projektmanagement Allgemein.....	11
Tabelle 4 Anforderungen Anwender Projektmanagement Beschaffung.....	12
Tabelle 5 Anforderungen Anwender Projektmanagment Beschaffung.....	13
Tabelle 6 Anforderungen Anwender Projektmanagement Personal.....	14
Tabelle 7 Anforderungen Anwender Dokumentation.....	15
Tabelle 8 Anforderungen Anwender Test und Freigabe.....	15
Tabelle 9 Anforderungen Anwender Installation.....	18
Tabelle 10 Anforderungen Anwender Patch- und Änderungsmanagement.....	19
Tabelle 11 Anforderungen Anwender Außerbetriebnahme.....	21
Tabelle 12 Anforderungen Produzent Projektmanagement Allgemein.....	22
Tabelle 13 Anforderungen Produzent Projektmanagement Personal.....	24
Tabelle 14 Anforderungen Produzent Projektdokumentation.....	25
Tabelle 15 Anforderungen Produzent Benutzerdokumentation.....	26
Tabelle 16 Anforderungen Produzent Entwicklung Entwicklungsmanagement.....	27
Tabelle 17 Anforderungen Produzent Entwicklung Entwurf.....	28
Tabelle 18 Anforderungen Produzent Entwicklung Bedrohungsmodellierung.....	29
Tabelle 19 Anforderungen Produzent Entwicklung Entwurf.....	30
Tabelle 20 Anforderungen Produzent Entwicklung Entwurfsprüfung.....	31
Tabelle 21 Anforderungen Produzent Entwicklungsbegleitende Tests.....	31
Tabelle 22 Anforderungen Produzent Entwicklung Drittkomponenten.....	32
Tabelle 23 Anforderungen Produzent Entwicklung Code Management.....	33
Tabelle 24 Anforderungen Produzent Compiler, Interpreter und Build-Werkzeuge.....	34
Tabelle 25 Anforderungen Produzent Entwicklung Inventarisierung.....	35
Tabelle 26 Anforderungen Produzent Entwicklung Test und Freigabe.....	35
Tabelle 27 Anforderungen Produzent Test und Freigabe für Patches- und Updates.....	37
Tabelle 28 Anforderungen Produzent Auslieferung.....	38
Tabelle 29 Anforderungen Produzent Schwachstellenmanagement.....	39
Tabelle 30 Anforderungen Produzent Außerbetriebnahme.....	41
Tabelle 31 Glossar.....	43

1 Einleitung

Sichere Soft- und Hardware bilden die Grundlage für den sicheren Einsatz von IT-Produkten in Staat, Wirtschaft und Gesellschaft. Das Bundesamt für Sicherheit in der Informationstechnik (BSI) fordert daher die Hersteller auf, Informationssicherheit von Anfang mitzudenken und es den Anwenderinnen und Anwendern durch eine sichere Vorkonfiguration so einfach wie möglich zu machen, ihre Produkte sicher zu nutzen.

Vor diesem Hintergrund wurde diese Technische Richtlinie (TR) ausgehend von den Anforderungen des BSI IT-Grundschatzes an sichere Software-Entwicklungs-Prozesse, ergänzt durch Normen, Standards und Frameworks, erstellt. Der Fokus lag dabei auf einer möglichen Anreicherung und Strukturierung.

Mit dem Cyber-Resilience-Act (CRA) stellt zudem auch die Europäische Union die Cybersicherheit von IT-Produkten über ihren gesamten Lebenszyklus in den Mittelpunkt der aktuellen Gesetzgebung und verpflichtet die Hersteller so zur Durchführung von entsprechenden Risikobetrachtungen und der Einhaltung von ausreichender Informationssicherheit.

Zielsetzung

Diese Technische Richtlinie

- listet und gruppiert Anforderungen aus bestehenden Normen und Standards,
- ermöglicht einen Einstieg in die Thematik des sicheren Software-Lebenszyklus,
- zeigt relevante Anforderungen im Kontext Informationssicherheit auf und
- bietet die Möglichkeit, die eigenen Entwicklungs-Prozesse mit Blick auf die Informationssicherheit zu bewerten und zu verbessern.

Sie betrachtet dazu

- die Prozesse im Kontext der Software-Erstellung und
- die verwendeten Hilfsmittel und Werkzeuge.

Die TR findet in ihrer Gesamtheit im aktuellen Stand keine Anwendung auf Prozesse zur Entwicklung von Software, die üblicherweise als „Open Source Software (OSS)“ oder „Free / Libre and Open Source Software (FLOSS / FOSS)“ bezeichnet wird. Für eine solche Anwendung müssen Anpassungen an solchen Anforderungen vorgenommen werden, die einer besonderen Berücksichtigung der Eigenheiten der Entwicklung von OpenSourceSoftware bedürfen.

2 Aufbau der TR

Zunächst werden in diesem Kapitel die Systematik der TR und die hierfür verwendeten Begriffe erläutert. Es folgen die Anforderungen in den möglichen Perspektiven des Software-Anwenders (Kapitel 3.1) und des Software-Produzenten (Kapitel 3.2).

2.1 Begriffsfestlegung

Hersteller

Als „Hersteller“ wird im Dokument eine natürliche oder juristische Person bezeichnet, die (unabhängig von der Organisationsform, unabhängig vom verwendeten Vorgehensmodell) als Verantwortlicher Software produziert d.h. entwickelt, erstellt, ausliefert/bereitstellt und supported.

Perspektiven

Der Blickwinkel, aus dem ein Hersteller im Software-Lebenszyklus agiert, kann differieren. Die Perspektiven des Herstellers sind im Dokument unterteilt in:

- **Software-Anwender:**
Dies beinhaltet Prozesse, Aktivitäten und Anforderungen bzgl. der zur Produktion **verwendeten Software**(-Werkzeuge).
- **Software-Produzent:**
Dies betrachtet Prozesse, Aktivitäten und Anforderungen bzgl. der **zu produzierenden Software**. Diese Perspektive beinhaltet immer auch die des „Software-Anwenders“.

Software-Lebenszyklus

Diese TR betrachtet Prozesse der Software-Erstellung auf Herstellerseite, aus der Perspektive Software-Anwender und Software-Produzent (siehe unten).

Der Prozess der Anforderungsdefinition (Requirementsdefinition) an die zu erstellende Software wird hier nicht betrachtet. Es wird davon ausgegangen, dass diesbezügliche Informationssicherheitsanforderungen dem Hersteller als Software-Produzent vorliegen bzw. bereitgestellt werden.

Prozesse und Anforderungen

Prozesse fassen Aktivitäten zur Erfüllung bzw. Umsetzung von Anforderungen an einen sicheren Software-Lebenszyklus zusammen und lassen sich den Perspektiven zuordnen.

Prozesse bzgl. der Perspektive „Software-Anwender“:

- Projektmanagement,
- Dokumentation,
- Test und Freigabe,
- Installation,
- Patch- und Änderungsmanagement und
- Außerbetriebnahme.

Prozesse bzgl. „Software-Produzent“ :

- Projektmanagement,
- Dokumentation,

- Entwicklung,
- Test und Freigabe,
- Auslieferung,
- Schwachstellenmanagement und
- Außerbetriebnahme.

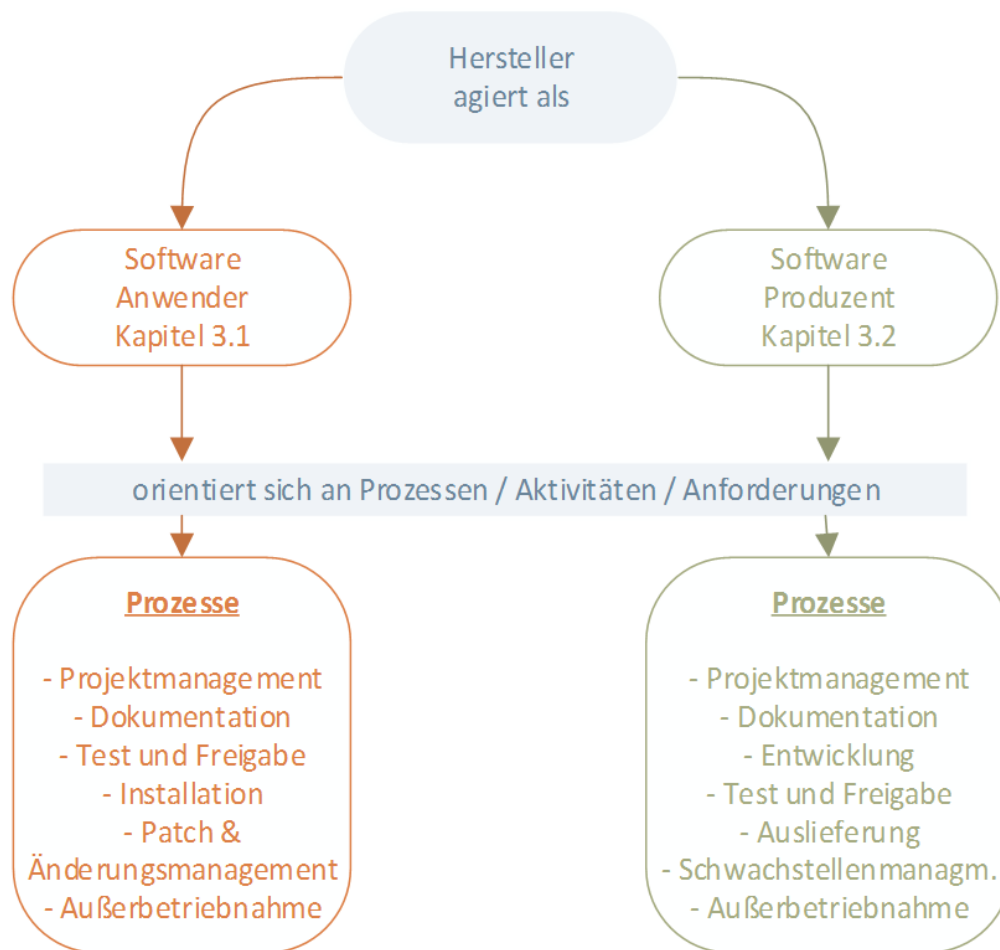


Abbildung 1: Perspektiven und Prozesse beim Hersteller

2.2 Hinweise und Erläuterungen

Informationssicherheitsmanagementsystem (ISMS)

Die informationssicherheitstechnische Betrachtung der Bereitstellung von IT und Infrastruktur als (unterstützende) Aufgabe auf Seiten des Herstellers sollte im Rahmen eines Informations-Sicherheitskonzeptes bzw. ISMS berücksichtigt werden (z.B. nach BSI IT-Grundschutz). Sie ist nicht Teil dieser TR.

Im Rahmen eines ISMS werden auch im vorliegenden Dokument verwendete Begriffe wie z.B. Schutzbedarf, Sicherheitsprofil, vertrauenswürdige Quelle verwendet und mit konkretem Inhalt belegt.

Projektierung

Das Dokument betrachtet insbesondere Aspekte zur Informationssicherheit und stellt keine Anleitung zur Projektierung von Software-Projekten dar.

Ebenso stellt die Reihenfolge der hier genannten Prozesse und Anforderungen keine bindende zeitliche Abfolge für ein Software-Projekt dar.

Vorgehensmodell

Die TR setzt kein spezielles Vorgehensmodell für die Software-Entwicklung voraus, vielmehr sind die hier beschriebenen Prozesse und Anforderungen so generisch, dass diese sich an das im Individualfall gewählte Vorgehensmodell (z.B. klassisch sequentiell oder agil) anpassen lassen.

Modalverben

In den Anforderungen werden die in Versalien geschriebenen Modalverben „SOLLTE“ und „MUSS“ in ihren jeweiligen Formen sowie den zugehörigen Verneinungen genutzt, um deutlich zu machen, wie die jeweiligen Anforderungen zu interpretieren sind. Die hier genutzte Definition basiert auf [RFC2119] sowie DIN 820-2:2012, Anhang H [820-2].

MUSS/DARF NUR:	Dieser Ausdruck bedeutet, dass es sich um eine Anforderung handelt, die unbedingt erfüllt werden muss (uneingeschränkte Anforderung).
DARF NICHT/DARF KEIN:	Dieser Ausdruck bedeutet, dass etwas in keinem Fall getan werden darf (uneingeschränktes Verbot).
SOLLTE:	Dieser Ausdruck bedeutet, dass eine Anforderung normalerweise erfüllt werden muss, es aber Gründe geben kann, dies doch nicht zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
SOLLTE NICHT/SOLLTE KEIN:	Dieser Ausdruck bedeutet, dass etwas normalerweise nicht getan werden sollte, es aber Gründe gibt, dies doch zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
KANN/KÖNNEN:	Dieser Ausdruck bedeutet, dass eine Anforderung fakultativ oder optional ist. Die im Dokument genannten Anforderungen sind als Beispiele anzusehen.

3 Anforderungen an den Hersteller

Die folgenden Kapitel nennen die Anforderungen für den Hersteller von Software. Diese wurden ausgehend vom BSI IT-Grundschutz-Kompendium aus verschiedenen Normen, Standards und Frameworks zusammengestellt. Dadurch können die Anforderungen einen unterschiedlichen Sprachstil und Detaillierungsgrad aufweisen.

Für einen Hersteller sind alle Anforderungen der beiden folgenden Kapitel (Perspektiven) relevant. Dies resultiert aus der Annahme, dass eine Software-Produktion nicht ohne IT-Unterstützung denkbar ist. Der mögliche Grad einer Werkzeug-Unterstützung kann dabei stark variieren.

Die verwendeten Quellen sind bei den aufgeführten Anforderungen zur weiteren Information jeweils referenziert. Grundlage waren:

- BSI IT-Grundschutz-Kompendium 2023
- NESAS, FS.16, Version 2.3
- DIN EN IEC 62443-4-1:2018-10
- NIST SP 800-218, Version 1.1, Februar 2022

Neben der Quellenangabe finden sich zu den Anforderungen weitere Informationen, nach folgender Systematik:

Tabelle 2 Systematik der Anforderungen

Anforderungs-ID	Kürzel der jeweiligen Anforderung
Weitere Informationen	Quellenangaben für weiterführende Informationen
Schlüsselworte	Im Text der Anforderung verwendete wichtige Begriffe
Glossar	Begriffe, die im Glossar erläutert sind

3.1 Anforderungen an den Hersteller als Anwender von Software

Dieses Kapitel nennt Anforderungen an den Hersteller in der Perspektive als Anwender von Software. Damit sind konkret Werkzeuge zur Unterstützung des Software-Lebenszyklus (z.B. für Projektmanagement, Dokumentation, Entwicklung, Testen, CI/CD) gemeint, die insbesondere in den Prozessen des Kapitels 3.2 zum Einsatz kommen.

Die Anforderungen untergliedern sich in:

- Projektmanagement (Allgemein, Beschaffung, IT-Betrieb, Personal),
- Dokumentation,
- Test und Freigabe,
- Installation,
- Patch- und Änderungsmanagement und
- Außerbetriebnahme.

3.1.1 Projektmanagement

Für den Einsatz von Werkzeugen zur Unterstützung des Software-Lebenszyklus ist ein Projektmanagement notwendig. Auch hier sind insbesondere Aspekte der Informationssicherheit zu beachten. Diesbezügliche Anforderungen sind in die Teilbereiche Allgemein, Beschaffung, IT-Betrieb und Personal gegliedert.

3.1.1.1 Allgemein

Allgemeine Überlegungen zur Definition der Anforderungen an die Software-Werkzeuge sind Basis für den weiteren Prozess bzgl. des Einsatzes von Werkzeugen. Im Folgenden werden diesbezügliche Anforderungen aufgeführt.

Tabelle 3 Anforderungen Anwender Projektmanagement Allgemein

Anforderungs-ID	Anforderung
USER.PM.A.1	Bevor eine Institution (neue) Software-Werkzeuge einführt, MUSS sie entscheiden und SOLLTE dokumentieren, - wofür die Software-Werkzeuge genutzt und welche Informationen (mit dem zugeordneten Schutzbedarf¹) damit verarbeitet werden sollen, - wie die Benutzer bei der Anforderungserhebung beteiligt und bei der Einführung unterstützt werden sollen, - wie die Software-Werkzeuge an weitere Anwendungen und IT-Systeme über welche Schnittstellen angebunden wird, - auf welchen IT-Systemen die Software-Werkzeuge ausgeführt werden soll und welche Ressourcen zur Ausführung der Software-Werkzeuge erforderlich sind, sowie - ob sich die Institution in Abhängigkeit zu einem Hersteller begibt, wenn sie diese Software-Werkzeuge einsetzt. Hierbei MÜSSEN bereits Sicherheitsaspekte berücksichtigt werden.
USER.PM.A.2	Auf Basis der Ergebnisse der Planung MÜSSEN die Anforderungen an die Software-Werkzeuge in einem Anforderungskatalog erhoben werden. Der Anforderungskatalog MUSS dabei die grundlegenden funktionalen Anforderungen umfassen. Darüber hinaus MÜSSEN die nichtfunktionalen Anforderungen und hier insbesondere die Sicherheitsanforderungen in den Anforderungskatalog integriert werden. Hierbei MÜSSEN sowohl die Anforderungen von den Fachverantwortlichen als auch vom IT-Betrieb berücksichtigt werden.
USER.PM.A.3	Es MÜSSEN auch die rechtlichen Anforderungen, die sich aus dem Kontext der zu verarbeitenden Daten ergeben, berücksichtigt werden.
USER.PM.A.4	Die Institution SOLLTE die nachfolgenden Sicherheitsanforderungen im Anforderungskatalog für die Software-Werkzeuge berücksichtigen: - Die Software-Werkzeuge SOLLTEN generelle Sicherheitsfunktionen wie Verschlüsselung, Protokollierung und Authentifizierung umfassen, die im Anwendungskontext erforderlich sind. - Die Software-Werkzeuge SOLLTEN es ermöglichen, die Härtungsfunktionen der Einsatzumgebung zu nutzen. Hierbei SOLLTEN insbesondere die Härtungsfunktionen des geplanten Betriebssystems und/oder der geplanten Ausführungsumgebung berücksichtigt werden (z.B. nicht benötigte Ports schließen, User-Berechtigungen sind minimal zu setzen). - Verwenden die Software-Werkzeuge (kryptografische) Zertifikate, dann SOLLTE sie die Möglichkeit bieten, die Zertifikate transparent darzustellen. Zudem SOLLTE es möglich sein, Zertifikate zu sperren,

¹ Diese Schutzbedarfe können sich von den Schutzbedarfen der zu erstellenden Software im späteren Einsatz unterscheiden.

Anforderungs-ID	Anforderung
	ihnen das Vertrauen zu entziehen oder eigene Zertifikate zu ergänzen. Die sich aus den Sicherheitsanforderungen ergebenden Funktionen der Software-Werkzeuge SOLLTEN im Betrieb verwendet werden.
USER.PM.A.5	Der fertige Anforderungskatalog SOLLTE mit allen betroffenen Fachabteilungen abgestimmt werden.
USER.PM.A.6	Für die verwendeten Werkzeuge KANN ein Nachweis² der vorhandenen Sicherheitsfunktionen in Betracht gezogen werden bzw. sinnvoll sein. An die herstellenden Unternehmen der Werkzeuge KÖNNEN hinreichende Anforderungen zur Sicherheit ihrer Werkzeuge gestellt werden.
	HINWEIS: Bzgl. folgender Prozesse gibt es weitere Anforderungen im Kontext Planung: - Installation, - Test und Freigabe, - Patch- und Änderungsmanagement und - Außerbetriebnahme.
Weitere Informationen	IT-Grundschutz-Kompendium, Bausteine APP.6, CON.8 NIST SP 800-218, Kapitel PO
Schlüsselworte	Anforderungskatalog, Schutzbedarf
Glossar	Fachverantwortliche

3.1.1.2 Beschaffung

Die Beschaffung von Software-Werkzeugen ist ein weiterer Aspekt im Projektmanagement. Im Folgenden werden diesbezügliche Anforderungen aufgeführt.

Tabelle 4 Anforderungen Anwender Projektmanagement Beschaffung

Anforderungs-ID	Anforderung
USER.PM.B.1	Anhand des Anforderungskatalogs SOLLTEN die am Markt erhältlichen Software-Werkzeuge gesichtet werden. Sie SOLLTEN mithilfe einer Bewertungsskala miteinander verglichen werden. Danach SOLLTE untersucht werden, ob die Software-Werkzeuge aus der engeren Wahl die Anforderungen der Institution erfüllen. Gibt es mehrere Alternativen für Software-Werkzeuge, SOLLTEN auch die Nutzerakzeptanz und der zusätzliche Aufwand für z. B. Schulungen oder die Migration berücksichtigt werden. Die Fachverantwortlichen SOLLTEN gemeinsam mit dem IT-Betrieb anhand der Bewertungen und Testergebnisse ein geeignetes Software-Werkzeug auswählen.
USER.PM.B.2	Wenn Software-Werkzeuge beschafft werden, MUSS auf Basis des Anforderungskatalogs eine geeignete Software ausgewählt werden. Das ausgewählte Software-Werkzeug MUSS aus vertrauenswürdigen Quellen³ beschafft werden. Die vertrauenswürdige Quelle SOLLTE eine Möglichkeit

² Nachweise sind z.B. Audits oder Zertifizierungen.

Anforderungs-ID	Anforderung
	bereitstellen, das Software-Werkzeug auf Integrität zu überprüfen. Darüber hinaus SOLLTE das Software-Werkzeug mit einem geeigneten Wartungsvertrag oder einer vergleichbaren Zusage des Herstellers oder Software-Anbieters beschafft werden. Diese Verträge oder Zusagen SOLLTEN insbesondere garantieren, dass auftretende Schwachstellen der Software-Werkzeuge während des gesamten Nutzungszeitraums zeitnah behoben werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein APP.6
Schlüsselworte	Beschaffung
Glossar	-

3.1.1.3 IT-Betrieb

Auch Anforderungen im Kontext des Betriebs von Software-Werkzeugen sind bzgl. der Planung zu berücksichtigen. Im Folgenden werden diesbezügliche Anforderungen aufgeführt.

Tabelle 5 Anforderungen Anwender Projektmanagement Beschaffung

Anforderungs-ID	Anforderung
USER.PM.C.1	Die Institution SOLLTE verbindlich regeln und in einem Dokument zusammenfassen, wie die Software-Werkzeuge eingesetzt und betrieben werden. Das Dokument SOLLTE allen relevanten Verantwortlichen, Zuständigen und Mitarbeitern der Institution bekannt sein und die Grundlage für ihre Arbeit und ihr Handeln bilden. Inhaltlich SOLLTE das Dokument auch ein Benutzer-Handbuch umfassen, dass erläutert, wie die Software-Werkzeuge (sicher) zu benutzen und zu administrieren sind. Es SOLLTE regelmäßig und stichprobenartig überprüft werden, ob die Mitarbeiter sich an die Vorgaben des Dokumentes halten. Das Dokument SOLLTE regelmäßig aktualisiert werden.
USER.PM.C.2	Es MUSS festgelegt werden, welche Arten von Software-Werkzeugen in Werkzeugketten integriert werden und wie diese miteinander verzahnt sind.
USER.PM.C.3	Bei Verteilung, Betrieb und Pflege der Werkzeuge SOLLTE der Stand der Technik befolgt werden.
USER.PM.C.4	Es SOLLTEN nur unbedingt notwendige Plug-ins und Erweiterungen installiert werden. Werden Erweiterungen eingesetzt, SOLLTE das Software-Werkzeug die Möglichkeit bieten, Erweiterungen zu konfigurieren und abzuschalten.
USER.PM.C.5	Das zu entwickelnde Software-Produkt MUSS im Entwicklungszyklus während Entwurf, Implementierung bis zur Freigabe und Lieferung mit Blick auf Vertraulichkeit, Verfügbarkeit und Integrität geschützt werden.

³ Jede Institution sollte prüfen und festlegen, welche internen, externen Quellen (z. B. Downloadseite vom Hersteller oder Original-Installationsmedium) als vertrauenswürdig erachtet werden. Hierbei sollte der individuelle Schutzbedarf berücksichtigt werden (ISMS).

Anforderungs-ID	Anforderung
USER.PM.C.6	Private Schlüssel für die Codesignatur, zum Schutz vor nicht autorisiertem Zugriff oder unberechtigter Abänderung, MÜSSEN besonders geschützt werden.
USER.PM.C.7	Ein regelmäßiges Sicherheitsaudit der Software-Entwicklungsumgebung und der Software-Testumgebung KANN in Betracht gezogen werden.
USER.PM.C.8	Eine regelmäßige Prüfung der Integrität der Entwicklungsumgebung mit kryptographischen Mechanismen entsprechend dem Stand der Technik KANN sinnvoll sein. Die Prüfsummendateien und das Prüfprogramm selbst SOLLTEN ausreichend vor Manipulationen geschützt sein. Wichtige Hinweise auf einen Integritätsverlust SOLLTEN nicht in einer Fülle irrelevanter Warnmeldungen (false positives) untergehen.
USER.PM.C.9	Umgebungen (z.B. Entwicklungs-, Build-, Testumgebung) SOLLTEN voneinander getrennt betrieben werden.
USER.PM.C.10	Alle Zugangspunkte (z.B. Benutzerkonten) für Entwickler, Tester, Designer etc. im Projekt MÜSSEN gehärtet und abgesichert werden.
Weitere Informationen	62443-4-1, Kapitel 5 (SM) NIST SP 800-218, Kapitel PO, PS IT-Grundschutz-Kompendium APP.6
Schlüsselworte	Entwicklungsumgebung, Dokumentation, Integrität, Benutzer-Handbuch, Werkzeugkette
Glossar	-

3.1.1.4 Personal

Die Klärung von Zuständigkeiten und Rollen und ggf. weitere Anforderungen zu Personal sind auch im Kontext des Einsatzes von Werkzeugen zur Software-Entwicklung wichtig. Im Folgenden werden entsprechende Anforderungen im Kontext Projektmanagement – Personal aufgeführt.

Tabelle 6 Anforderungen Anwender Projektmanagement Personal

Anforderungs-ID	Anforderung
USER.PM.D.1	Die Institution MUSS die Zuständigkeiten für fachliche Betreuung, Freigabe und betriebliche Administration schon im Vorfeld klären und festlegen. Die Zuständigkeiten MÜSSEN dokumentiert und bei Bedarf aktualisiert werden.
USER.PM.D.2	Es MUSS ein(e) Verantwortliche(r) für die Informationssicherheit festgelegt werden.
USER.PM.D.3	Alle Mitarbeitenden MÜSSEN über die festgelegten Zuständigkeiten informiert sein, insbesondere wofür sie zuständig sind und welche damit verbundenen Aufgaben sie wahrnehmen.
USER.PM.D.4	Die Aufgaben und die hierfür erforderlichen Rollen und Funktionen SOLLTEN so strukturiert sein, dass unvereinbare Aufgaben wie operative und kontrollierende Funktionen auf verschiedene Personen verteilt werden. Für unvereinbare

Anforderungs-ID	Anforderung
	Funktionen SOLL eine Funktionstrennung festgelegt und dokumentiert sein. Auch Vertreter MÜSSEN der Funktionstrennung unterliegen.
USER.PM.D.5	Die Mitarbeitenden MÜSSEN entsprechend ihrer jeweiligen Aufgabe ausreichend geschult sein. Die Schulungen SOLLTEN regelmäßig wiederholt werden.
	HINWEIS: Bzgl. folgender Prozesse gibt es weitere Anforderungen im Kontext Personal: • Test und Freigabe • Patch- und Änderungsmanagement
Weitere Informationen	IT-Grundschutz-Kompendium, Bausteine APP.6, ORP.1, ORP.2, OPS.1.1.3, OPS.1.1.6
Schlüsselworte	Zuständigkeiten, Rollen, Dokumentation, Schulung, Funktionstrennung
Glossar	-

3.1.2 Dokumentation

Das Verschriftlichen von getroffenen Absprachen und Regelungen spielt hinsichtlich des Einsatzes von Werkzeugen zur Software-Entwicklung eine wichtige Rolle. Im Folgenden werden die Anforderungen im Kontext Dokumentation aufgeführt.

Tabelle 7 Anforderungen Anwender Dokumentation

Anforderungs-ID	Anforderung
USER.DOC.1	Zu allen getroffenen Regelungen SOLL eine Dokumentation erstellt und aktuell gehalten werden.
Weitere Informationen	-
Schlüsselworte	Dokumentation
Glossar	-

3.1.3 Test und Freigabe

Test und Freigabe von Software-Werkzeugen erfolgen vor der Installation und Nutzung. Im Folgenden werden die diesbezüglichen Anforderungen aufgeführt.

Tabelle 8 Anforderungen Anwender Test und Freigabe

Anforderungs-ID	Anforderung
USER.TESTRELA.1	Die Rahmenbedingungen für Software-Tests MÜSSEN vor den Tests festgelegt werden. Berücksichtigt werden MÜSSEN: • innerhalb der Institution geltende Schutzbedarfe, Organisationseinheiten, technischen Möglichkeiten und Test-Umgebungen, • Anforderungen des Anforderungskatalogs. Liegt auch ein Pflichtenheft vor, dann MUSS dieses zusätzlich berücksichtigt werden,

Anforderungs-ID	Anforderung
	• Auswahl der Testfälle, sodass diese repräsentativ alle im Anforderungskatalog spezifizierten Funktionen der Software überprüfen. Zusätzlich MÜSSEN auch Negativ-Tests berücksichtigt werden, • Auswahl der Testumgebung, sodass diese repräsentativ die IT-Infrastruktur beim Hersteller abdeckt. Es MUSS dabei getestet werden, ob die Software mit den eingesetzten Betriebssystemen in den vorliegenden Konfigurationen kompatibel und funktionsfähig ist.
USER.TESTREL.A.2	Folgendes SOLLTE schriftlich festgelegt werden: • die durchzuführenden Testarten, Testfälle und die erwarteten Ergebnisse, • die Freigabekriterien und • eine Vorgehensweise für die Situation, wenn eine Freigabe abgelehnt wird.
USER.TESTREL.A.3	Bei der Auswahl der Software-Tester SOLLTEN folgende Auswahlkriterien berücksichtigt werden: • Die Software-Tester SOLLTEN die erforderliche berufliche Qualifikation haben. • Wird Software auf Quellcode-Ebene überprüft, dann SOLLTEN die Tester über ausreichendes Fachwissen über die zu testenden Programmiersprache und der Entwicklungsumgebung verfügen.
USER.TESTREL.A.4	Der Fachverantwortliche SOLLTE die Software-Tester informieren über • die mindestens durchzuführenden Testarten und die zu testenden Bereiche einer Software, • die Anwendungsfälle und mögliche weitere Anforderungen der Software.
USER.TESTREL.A.5	Sofern Testende auf besonders schützenswerte Informationen zugreifen müssen, KANN es z.B. sinnvoll sein, dass die Institution Nachweise über ihre Integrität und Reputation einholt. Hierzu SOLLTE der oder die Informationssicherheitsbeauftragte (ISB) die Geheimschutzbeauftragten bzw. Sicherheitsbevollmächtigten der Institution einbeziehen.
USER.TESTREL.A.6	Wenn Produktivdaten für Software-Tests verwendet werden, die schützenswerte Informationen enthalten, dann MÜSSEN diese Testdaten angemessen geschützt werden. Enthalten diese Daten personenbezogene Informationen, dann MÜSSEN diese Daten mindestens pseudonymisiert werden.
USER.TESTREL.A.7	Software SOLLTE nur in einer hierfür vorgesehenen Testumgebung getestet werden. Die Testumgebung SOLLTE von der Produktivumgebung getrennt betrieben werden. Die in der Testumgebung verwendeten Architekturen und Mechanismen SOLLTEN dokumentiert werden. Es SOLLTEN Verfahren dokumentiert werden, wie mit der Testumgebung nach Abschluss des Software-Tests zu verfahren ist.
USER.TESTREL.A.8	Die Software MUSS auf Basis der in der Planung festgelegten Rahmenbedingungen (s.o. Anforderungskatalog bei USER.PM.A.2) getestet werden.
USER.TESTREL.A.9	Die Installation der Software-Werkzeuge SOLLTE entsprechend der Regelungen zur Installation und Konfiguration von Software überprüft werden. Falls

Anforderungs-ID	Anforderung
	vorhanden, SOLLTE zusätzlich die Installations- und Konfigurationsdokumentation geprüft werden.
USER.TESTRELA.10	Mit funktionalen Software-Tests MUSS die ordnungsgemäße aller im Anforderungskatalog spezifizierten Funktionen der Software-Werkzeuge überprüft werden. Die funktionalen Software-Tests MÜSSEN so durchgeführt werden, dass sie den Produktivbetrieb nicht beeinflussen.
USER.TESTRELA.11	Es MÜSSEN Software-Tests durchgeführt werden, die überprüfen, ob alle wesentlichen nicht-funktionalen Anforderungen erfüllt werden. Insbesondere MÜSSEN sicherheitsspezifische Software-Tests durchgeführt werden, wenn das Software-Werkzeug sicherheitskritische Funktionen mitbringt.
USER.TESTRELA.12	Wenn Software verändert wurde, SOLLTEN Regressionstests durchgeführt werden. Hierbei SOLLTE überprüft werden, ob bisherige bestehende Sicherheitsmechanismen und -einstellungen durch das Update ungewollt verändert wurden. Regressionstests SOLLTEN vollständig durchgeführt werden und hierbei auch Erweiterungen sowie Hilfsmittel umfassen. Werden Testfälle ausgelassen, SOLLTE dies begründet und dokumentiert werden.
USER.TESTRELA.13	Ein Penetrationstest als Testmethode KANN für die Werkzeuge in Betracht gezogen werden. Ein Konzept für Penetrationstests SOLLTE erstellt werden. Im Konzept für Penetrationstests SOLLTEN neben den zu verwendenden Testmethoden auch die Erfolgskriterien dokumentiert werden. Der Penetrationstest SOLLTE nach den Rahmenbedingungen des Penetrationstest-Konzepts erfolgen. Die durch den Penetrationstest aufgefundenen Sicherheitslücken SOLLTEN klassifiziert und dokumentiert sein.
USER.TESTRELA.14	Die Ergebnisse der Software-Tests MÜSSEN ausgewertet und dokumentiert werden. Es SOLLTE ein Soll-Ist-Vergleich mit definierten Vorgaben durchgeführt werden.
USER.TESTRELA.15	Die zuständige Organisationseinheit MUSS überprüfen, ob die Software-Werkzeuge gemäß den Anforderungen getestet wurden. Die Ergebnisse der Software-Tests MÜSSEN mit den vorher festgelegten Erwartungen übereinstimmen. Auch MUSS überprüft werden, ob die rechtlichen und organisatorischen Vorgaben eingehalten wurden.
USER.TESTRELA.16	Die zuständige Organisationseinheit MUSS die Software-Werkzeuge freigeben, sobald die Software-Tests erfolgreich durchgeführt wurden. Die Freigabe MUSS dokumentiert werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein OPS.1.1.6
Schlüsselworte	Test, Freigabe, Regressionstest, Penetrationstest, Produktivdaten, Testumgebung
Glossar	-

3.1.4 Installation

Bei der Installation von Werkzeugen sind die im folgenden aufgeführten Anforderungen relevant.

Tabelle 9 Anforderungen Anwender Installation

Anforderungs-ID	Anforderung
USER.INST.1	Die Installation und Konfiguration der Software-Werkzeuge und abhängiger Komponenten MUSS durch den IT-Betrieb geregelt und dokumentiert werden (z.B. manuelle und/oder automatische Installation). Dabei ist zu beachten dass
USER.INST.2	die Integrität der „Installationsdateien“ vor Installation überprüft wird,
USER.INST.3	Software-Werkzeuge nur mit Lizenzen eingesetzt werden, die dem Einsatzzweck und den vertraglichen Bestimmungen entspricht,
USER.INST.4	- die Software-Werkzeuge nur mit dem geringsten notwendigen Funktionsumfang installiert und ausgeführt werden, - die Software-Werkzeuge mit den geringsten möglichen Berechtigungen ausgeführt werden, - die datensparsamsten Einstellungen (in Bezug auf die Verarbeitung von personenbezogenen Daten) konfiguriert werden, - alle relevanten Sicherheitsupdates und -patches nach Risikoabwägung installiert sind, bevor die Software-Werkzeuge produktiv eingesetzt werden sowie - in Abstimmung mit dem Fachverantwortlichen festlegt wird, wer die Software-Werkzeuge wie installieren darf.
USER.INST.5	ausschließlich unveränderte Versionen der freigegebenen Software-Werkzeuge verwendet werden.
USER.INST.6	die Verfügbarkeit der Installations- und Konfigurationsdateien auch nach der Installation sichergestellt ist.
USER.INST.7	Software-Werkzeuge MÜSSEN entsprechend der getroffenen Regelungen installiert werden.
USER.INST.8	In einem aktuellen Bestandsverzeichnis SOLLTE dokumentiert werden, auf welchen Systemen die Software-Werkzeuge unter welcher Lizenz eingesetzt werden. Zusätzlich SOLLTEN die sicherheitsrelevanten Einstellungen mit erfasst werden. Das Bestandsverzeichnis SOLLTE so aufgebaut sein, dass bei Sicherheitsvorfällen eine schnelle Gesamtübersicht mit den notwendigen Details (z.B. SBOM) ermöglicht wird.
USER.INST.9	Werkzeuge MÜSSEN so konfiguriert sein, dass sie auch die vorher festgelegten (Meta-) Daten über die durchgeführte Aufgabe liefern. Diese dienen als Messwerte und helfen bei der Überprüfung der Wirksamkeit der Werkzeuge.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein APP.6 NIST SP 800-218, Kapitel PO
Schlüsselworte	Bestandsverzeichnis, Lizenz, Installation
Glossar	-

3.1.5 Patch- und Änderungsmanagement

Mit einem Patch von einem Software-Werkzeug kann eine Behebung von Fehlern/Schwachstellen erfolgen. Gewünschte Änderungen an Software-Werkzeugen werden in einem Prozess des Änderungsmanagements behandelt.

Tabelle 10 Anforderungen Anwender Patch- und Änderungsmanagement

Anforderungs-ID	Anforderung
USER.PATCH.A.1	Es MÜSSEN Zuständigkeiten für das Patch- und Änderungsmanagement festgelegt werden. Diese sind im Rollenkonzept zu dokumentieren (vgl. Anforderung „Personal“).
USER.PATCH.A.2	Wenn IT-Komponenten, Software-Werkzeuge oder Konfigurationsdaten geändert werden, MUSS es dafür Vorgaben geben, die auch Sicherheitsaspekte berücksichtigen. Diese MÜSSEN in einem Dokument für das Patch- und Änderungsmanagement festgehalten und befolgt werden. Insgesamt MUSS sichergestellt werden, dass das angestrebte Sicherheitsniveau während und nach den Änderungen erhalten bleibt. Insbesondere SOLLTEN auch die gewünschten Sicherheitseinstellungen erhalten bleiben.
USER.PATCH.A.3	Innerhalb des Dokumentes zum Patch- und Änderungsmanagement MUSS definiert werden, wie mit integrierten Update-Mechanismen (Autoupdate) der eingesetzten Software umzugehen ist. Insbesondere MUSS festgelegt werden, wie diese Mechanismen abgesichert und passend konfiguriert werden. Außerdem SOLLTEN neue Komponenten daraufhin überprüft werden, welche Update-Mechanismen sie haben.
USER.PATCH.A.4	Während des gesamten Patch- oder Änderungsprozesses SOLLTE die Authentizität und Integrität von Softwarepaketen sichergestellt werden.
USER.PATCH.A.5	Alle Patches und Änderungen MÜSSEN geeignet geplant, genehmigt und dokumentiert werden.
USER.PATCH.A.6	Patches und Änderungen SOLLTEN vorab geeignet getestet werden (siehe hierzu auch Kapitel Test und Freigabe)
USER.PATCH.A.7	Wenn Patches installiert und Änderungen durchgeführt werden, MÜSSEN Rückfall-Lösungen vorhanden sein.
USER.PATCH.A.8	Bei Änderungen, die die Informationssicherheit betreffen können, MUSS der ISB beteiligt sein.
USER.PATCH.A.9	Für zeitweise oder längerfristig nicht erreichbare Geräte SOLLTE festgelegt werden, wie diese Patches und Änderungen erhalten.
USER.PATCH.A.10	Alle Änderungsanforderungen (CR/Request for Changes, RfCs) SOLLTEN erfasst und dokumentiert und vom Fachverantwortlichen daraufhin kontrolliert werden, ob die Aspekte der Informationssicherheit ausreichend berücksichtigt wurden.
USER.PATCH.A.11	Der zu einer Änderung zugehörige Abstimmungsprozess SOLLTE alle relevanten Zielgruppen und die Auswirkungen auf die Informationssicherheit

Anforderungs-ID	Anforderung
	berücksichtigen. Die von der Änderung betroffenen Zielgruppen SOLLTEN sich nachweisbar dazu äußern können. Auch SOLLTE es ein festgelegtes Verfahren geben, wodurch wichtige Änderungsanforderungen beschleunigt werden können.
USER.PATCH.A.12	Der Änderungsmanagementprozess SOLLTE in die Geschäftsprozesse beziehungsweise Fachaufgaben integriert werden. Bei geplanten Änderungen SOLLTE die aktuelle Situation der davon betroffenen Geschäftsprozesse berücksichtigt werden. Alle relevanten Fachabteilungen SOLLTEN über anstehende Änderungen informiert werden. Auch SOLLTE es eine Eskalationsebene geben.
USER.PATCH.A.13	Es SOLLTE überprüft werden, ob eine Änderung erfolgreich war. Die Ergebnisse der Nachtests SOLLTEN dokumentiert werden.
USER.PATCH.A.14	Änderungen SOLLTEN in allen Phasen, allen Anwendungen und allen Systemen dokumentiert werden. Dazu SOLLTEN entsprechende Regelungen erarbeitet werden.
USER.PATCH.A.15	IT-Systeme und Software-Werkzeuge SOLLTEN regelmäßig aktualisiert werden. Grundsätzlich SOLLTEN Patches zeitnah nach Veröffentlichung eingespielt werden. Hierbei sind folgende Aspekte zu beachten: • Basierend auf dem Konzept für das Patch- und Änderungsmanagement MÜSSEN Patches zeitnah nach Veröffentlichung bewertet und entsprechend priorisiert werden. Für die Bewertung SOLLTE geprüft werden, ob es zu diesem Patch bekannte Schwachstellen gibt. • Es MUSS entschieden werden, ob der Patch eingespielt werden soll: ○ Wenn ein Patch eingespielt wird, SOLLTE kontrolliert werden, ob dieser auf allen relevanten Systemen zeitnah erfolgreich eingespielt wurde. ○ Wenn ein Patch nicht eingespielt wird, MÜSSEN die Entscheidung und die Gründe dafür dokumentiert werden. Falls Software-Werkzeuge eingesetzt werden sollen, die nicht mehr von den Herstellenden unterstützt werden oder für die kein Support mehr vorhanden ist, MUSS geprüft werden, ob diese dennoch sicher betrieben werden können. Ist dies nicht der Fall, DÜRFEN diese Software-Werkzeuge NICHT mehr verwendet werden.
USER.PATCH.A.16	Wenn Werkzeuge für das Patch- und Änderungsmanagement eingesetzt werden, SOLLTEN informationssicherheitsspezifische Regelungen als verbindlich dokumentiert werden.
USER.PATCH.A.17	Werden Werkzeuge für das Patch- und Änderungsmanagement genutzt, KÖNNEN Unterbrechungspunkte definiert werden, an denen die Verteilung einer fehlerhaften Änderung gestoppt wird.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein OPS.1.1.3
Schlüsselworte	Patch, Änderungsmanagement
Glossar	-

3.1.6 Außerbetriebnahme

Es ist zu regeln, wie mit nicht mehr genutzter Software umzugehen ist. Eine mögliche Außerbetriebnahme geschieht dabei kontrolliert.

Tabelle 11 Anforderungen Anwender Außerbetriebnahme

Anforderungs-ID	Anforderung
USER.DECOM.1	Wenn Software-Werkzeuge außer Betrieb genommen werden, SOLLTE geregelt werden, wie dies im Detail durchzuführen ist. Ebenfalls SOLLTE geregelt werden, wie die Benutzer hierüber zu informieren sind. Hierbei SOLLTE geklärt werden, ob die funktionalen Anforderungen fortbestehen (z. B. zur Bearbeitung von Fachaufgaben). Ist dies der Fall, dann SOLLTE geregelt werden, wie die benötigten Funktionen der betroffenen Software-Werkzeuge weiter verfügbar sein werden.
USER.DECOM.2	Werden Software-Werkzeuge gemäß den Regelungen zur Außerbetriebnahme deinstalliert, MÜSSEN • alle angelegten und nicht mehr benötigten Dateien entfernt werden, • alle Einträge in Systemdateien, die für das Produkt vorgenommen wurden und nicht länger benötigt werden, rückgängig gemacht werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein APP.6
Schlüsselworte	Außerbetriebnahme, Deinstallation
Glossar	-

3.2 Anforderungen an den Hersteller als Software-Produzent

In diesem Kapitel werden die Anforderungen an den Hersteller in der Perspektive als Produzent von Software dargestellt.

Das Kapitel teilt sich auf in die Bereiche

- Projektmanagement (Allgemein, Personal),
- Dokumentation (Projektdokumentation, Benutzerdokumentation),
- Entwicklung (Entwicklungsmanagement, Entwurf, Bedrohungsmodellierung, Entwurf/ Architektur, Entwurfsprüfung, Entwicklungsbegleitende Tests, Drittkomponenten, Code Management, Werkzeuge, Inventarisierung),
- Test und Freigabe (Patches und Updates),
- Auslieferung,
- Schwachstellenmanagement und
- Außerbetriebnahme.

HINWEIS: Der Prozess der Anforderungsdefinition (Requirementsdefinition) an zu erstellende Software wird aktuell hier nicht betrachtet. Es wird davon ausgegangen, dass diesbezügliche Informationssicherheitsanforderungen aktuell vorliegen bzw. bereitgestellt werden.

3.2.1 Projektmanagement

Die Planung der Software-Erstellung ist insbesondere hinsichtlich Aspekten der Informationssicherheit wichtig. Dabei stehen für den Hersteller die Anforderungen an das Produkt, an die eigene Organisation, die Prozesse und ggf. die technische Infrastruktur beim Hersteller, im Fokus.

3.2.1.1 Allgemein

Im Folgenden werden übergeordnete Aspekte zur Software-Erstellung und Anforderungen hinsichtlich Informationssicherheit thematisiert.

Tabelle 12 Anforderungen Produzent Projektmanagement Allgemein

Anforderungs-ID	Anforderung
PROD.PM.A.1	Bei Projektstart MÜSSEN alle Informationssicherheitsanforderungen für die Infrastruktur und Prozesse der Software-Entwicklung identifiziert, dokumentiert, bekannt sein und aktuell gehalten werden.
PROD.PM.A.2	Bei Projektstart MÜSSEN alle Informationssicherheitsanforderungen für die zu entwickelnde Software identifiziert, dokumentiert, bekannt sein und aktuell gehalten werden.
PROD.PM.A.3	Zu jedem Entwicklungsprojekt MUSS ein Verfahren existieren, dass die Informationssicherheitsanforderungen an das Produkt und das Produktumfeld dahingehend untersucht, dass sie • aktuell, nachvollziehbar und gültig sind und • im Einklang mit den Ergebnissen der Bedrohungsmodellierung stehen. In dieses Verfahren sind • mit der Realisierung beauftragte Entwickler, • unabhängige Prüfer, • Auftraggeber sowie • mit der Informationssicherheit des Projektes beauftragte Personen einzubeziehen.
PROD.PM.A.4	Geeignete Qualitätsziele SOLLTEN für das Entwicklungsprojekt definiert werden.
PROD.PM.A.5	Ein geeignetes Vorgehensmodell zur Software-Entwicklung (inkl. Wartung) MUSS festgelegt werden. Anhand des gewählten Vorgehensmodells MUSS ein Ablaufplan für die Software-Entwicklung erstellt werden. Die Informationssicherheitsanforderungen an die Vorgehensweise MÜSSEN im Vorgehensmodell integriert werden.
PROD.PM.A.6	Für das Vorgehensmodell SOLLTE ein geeignetes Risikomanagement festgelegt werden.
PROD.PM.A.7	Das ausgewählte Vorgehensmodell, einschließlich der festgelegten Informationssicherheitsanforderungen, MUSS eingehalten werden.
PROD.PM.A.8	Bei einer Software-Entwicklung SOLLTE ein geeignetes Steuerungs- bzw. Projektmanagementmodell auf Basis des ausgewählten Vorgehensmodells verwendet werden.

Anforderungs-ID	Anforderung
	Bei der Auswahl des Steuerungs-/Projektmanagementmodell SOLLTEN insbesondere die benötigten Qualifikationen beim Personal und die Abdeckung aller relevanten Phasen während des Lebenszyklus der Software berücksichtigt werden.
PROD.PM.A.9	Es SOLLTE eine Dokumentation zu Vorgaben für die Software-Entwicklung erstellt und aktuell gehalten werden. Die Dokumentation zu Vorgaben der Software-Entwicklung SOLLTE neben Namenskonventionen auch Vorgaben zu Elementen beinhalten, die verwendet bzw. nicht verwendet werden dürfen. Die Dokumentation zu Vorgaben der Software-Entwicklung SOLLTE für die Entwickler verbindlich sein.
PROD.PM.A.10	Das Steuerungs- bzw. Projektmanagementmodell SOLLTE in die verbindliche Dokumentation zur Software Entwicklung integriert werden.
PROD.PM.A.11	Ein Werkzeug zur Versionierung des Projektes MUSS eingesetzt werden, um Entscheidungen, Änderungen und deren Verantwortlichkeiten feststellen und zurückverfolgen zu können.
PROD.PM.A.12	Es MUSS eine Vorgehensweise festgelegt werden, mit der alle Anforderungen und Designänderungen während des gesamten Entwicklungs- und Software-Lebenszyklus dokumentiert und verwaltet werden.
PROD.PM.A.13	Der Hersteller MUSS für den gesamten Software-Lebenszyklus den Schutzbedarf der Informationen zum Produkt (z.B. zu Schwachstellen, Schlüssel für Signierung) festlegen und die schutzbedürftigen Informationen entsprechend schützen.
PROD.PM.A.14	Es MUSS ein Verfahren existieren, dass vor Freigabe eines Produktes dokumentiert, dass alle das Produkt betreffenden sicherheitsbezogenen Aktivitäten erfolgreich beendet wurden.
PROD.PM.A.15	Alle Prozesse des Software-Lebenszyklus MÜSSEN einem Prozessreview (Qualitätsmanagement) mit dem Ziel der stetigen Verbesserung zugeführt werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 NESAS, Kapitel [REQ-GEN] 62443-4-1, Kapitel 5 (SM), 6 (SR), 10 (DM) NIST SP 800-218, Kapitel PO, RV
Schlüsselworte	Projektmanagement, Vorgehensmodell, Informationssicherheitsanforderungen, Dokumentation, Prozessreview, Verbesserung, Qualitätsmanagement
Glossar	Vorgehensmodell

3.2.1.2 Personal

Die Bedeutung von Informationssicherheit für eine Institution und ihre Geschäftsprozesse muss für alle beteiligten Personen transparent und nachvollziehbar sein. Im Folgenden geht es um die Festlegung von Rollen und Zuständigkeiten im Software-Entwicklungsprozess.

Tabelle 13 Anforderungen Produzent Projektmanagement Personal

Anforderungs-ID	Anforderung
PROD.PM.C.1	Für den Software-Entwicklungsprozess SOLLTE eine gesamtzuständige Person benannt werden. Außerdem SOLLTEN die Rollen und Zuständigkeiten für alle Aktivitäten im Rahmen der Software-Entwicklung festgelegt werden. Die Rollen SOLLTEN dabei fachlich die nachfolgenden Themen abdecken: • Anforderungs- (Requirements-Engineering) und Änderungsmanagement, • Software-Entwurf und -Architektur, • Informationssicherheit in der Software-Entwicklung, • Software-Implementierung in dem für das Entwicklungsvorhaben relevanten Bereichen, sowie • Software-Tests. Für jedes Entwicklungsvorhaben SOLLTE eine zuständige Person für die Informationssicherheit benannt werden.
PROD.PM.C.2	Die Aufgaben und die hierfür erforderlichen Rollen und Funktionen SOLLTEN so strukturiert sein, dass unvereinbare Aufgaben wie operative und kontrollierende Funktionen auf verschiedene Personen verteilt werden. Für unvereinbare Funktionen SOLL eine Funktionstrennung festgelegt und dokumentiert sein. Auch Vertreter MÜSSEN der Funktionstrennung unterliegen.
PROD.PM.C.3	Die Zuständigkeiten MÜSSEN mit dem Management abgestimmt und den Zuständigen mitgeteilt werden.
PROD.PM.C.4	Die Rollen und Verantwortlichkeiten MÜSSEN regelmäßig bewertet und wenn notwendig angepasst werden.
PROD.PM.C.5	Die Entwickelnden und die übrigen Mitglieder des Entwicklungsteams SOLLTEN zu generellen Informationssicherheitsaspekten und zu den jeweils speziell für sie relevanten Aspekten geschult sein: • Anforderungsanalyse, • Projektmanagement allgemein sowie speziell bei der Software-Entwicklung, • Risikomanagement bzw. Bedrohungsmodellierung in der Software-Entwicklung, • Qualitätsmanagement und Qualitätssicherung, • Modelle, Methoden und Best Practices für die Software-Entwicklung, • Software-Architektur, • Software-Tests, • Änderungsmanagement sowie • Informationssicherheit, Sicherheitsvorgaben in der Institution und Sicherheitsaspekte in speziellen Bereichen.
PROD.PM.C.6	Durchgeführte Schulungen und die jeweiligen Ergebnisse SOLLTEN dokumentiert werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Bausteine CON.8, ORP.1 62443-4-1, Kapitel 5 (SM) NIST SP 800-218, Kapitel PO NESAS, Kapitel [REQ-GEN]

Anforderungs-ID	Anforderung
Schlüsselworte	Schulung, Rollen, Dokumentation, Funktionstrennung
Glossar	-

3.2.2 Dokumentation

Die in einem (Entwicklungs-)Projekt zu führende Dokumentation lässt sich unterteilen in Projekt- und Benutzerdokumentation. Dabei sollte die Projektdokumentation alles beinhalten, was die Nachvollziehbarkeit von Entscheidungen und den Nachweis von Ergebnissen im Projekt (der Erstellung einer Software) ermöglicht.

Davon zu unterscheiden ist die Benutzerdokumentation, die alle wichtigen Informationen zur Software für den späteren Anwender bereit hält.

Die Anforderungen in diesen beiden Bereichen sind in den beiden folgenden Tabellen genannt.

3.2.2.1 Projektdokumentation

Tabelle 14 Anforderungen Produzent Projektdokumentation

Anforderungs-ID	Anforderung
PROD.DOC.A.1	Es SOLLTEN ausreichende Projekt-, Funktions- und Schnittstellendokumentationen erstellt und aktuell gehalten werden. Die Software-Entwicklung SOLLTE so dokumentiert sein, dass Fachleute mithilfe der Dokumentation den Programm-Code nachvollziehen und weiterentwickeln können. Die Dokumentation SOLLTE dabei auch die Software-Architektur und das Bedrohungsmodellierung umfassen. Die Aspekte zur Dokumentation SOLLTEN im Vorgehensmodell zur Software-Entwicklung berücksichtigt werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8
Schlüsselworte	Dokumentation, Projektdokumentation
Glossar	-

3.2.2.2 Benutzerdokumentation

Tabelle 15 Anforderungen Produzent Benutzerdokumentation

Anforderungs-ID	Anforderung
PROD.DOC.B.1	Es MUSS eine Benutzerdokumentation erstellt werden, die konkrete Sicherheitshinweise für die Installation und Konfiguration (Stichwort: security by default) für Admins, sowie für die Benutzung des Produktes/der Software für den Anwender beinhaltet.
PROD.DOC.B.2	Die Benutzerdokumentation MUSS die Sicherheitsstrategie des Produktes

Anforderungs-ID	Anforderung
	darstellen und die zugesicherten Produkteigenschaften aufführen.
PROD.DOC.B.3	Die Dokumentation MUSS Angaben zu den vom Einsatzumfeld benötigten Voraussetzungen (mit Blick auf die Sicherheitsstrategie des Produkts (Defense in Depth)) enthalten.
PROD.DOC.B.4	Es MÜSSEN konkrete Hinweise bzw. Anleitungen für die Härtung, bei Installation und Pflege des Produktes erstellt und dokumentiert werden.
PROD.DOC.B.5	insichtlich des Produkteinsatzes MÜSSEN bzgl. der Verwaltung der Nutzerkonten Anforderungen und Empfehlungen getroffen und dokumentiert werden, wenn das Produkt Nutzerkonten vorsieht.
PROD.DOC.B.6	Die Benutzerdokumentation MUSS sich auf die ausgelieferte Software-Version beziehen sowie aktuell, exakt und vollständig sein.
	HINWEIS: Im Rahmen folgender Prozesse könnten ggf. Änderungen/Anpassungen an der Benutzerdokumentation erforderlich sein: • Entwicklung, • Test und Freigabe, • Schwachstellenmanagement und • Außerbetriebnahme.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 62443-4-1, Kapitel 12 (SG) NESAS, Kapitel [REQ-REL]
Schlüsselworte	Dokumentation, Benutzerdokumentation
Glossar	gestaffelte Sicherheitsstrategie/Defense-in-Depth-Strategie

3.2.3 Entwicklung

Mit der Entwicklung beginnt die Umsetzung des Projektes. Basis sind die im Rahmen der erfolgten Analyse spezifizierten Anforderungen an die Software (Requirements). Die Durchführung der Bedrohungsmodellierung stellt einen wichtigen Aspekt dar. Bei der Umsetzung in Programmcode spielen die eingesetzten Drittkomponenten, die eingesetzten Werkzeuge, als auch die entwicklungsbegleitenden Tests eine wichtige Rolle.

Die im folgenden aufgeführten Anforderungen können dabei unterstützen, technische Schulden zu vermeiden.

3.2.3.1 Entwicklungsmanagement

Es gibt ein allgemeines Regelwerk, was grundsätzliche Vorgaben/Rahmenbedingungen für alle Beteiligten definiert.

Tabelle 16 Anforderungen Produzent Entwicklung Entwicklungsmanagement

Anforderungs-ID	Anforderung
PROD.DEV.A.1	Insbesondere die Informationssicherheitsanforderungen, Risiken und damit zusammenhängende Designentscheidungen für die zu erstellende Software

Anforderungs-ID	Anforderung
	MÜSSEN nachverfolgt und gepflegt werden.
PROD.DEV.A.2	Es SOLLTEN bereits verfügbare Software-Komponenten verwendet werden, wenn sie die festgelegten Informationssicherheitsanforderungen erfüllen.
PROD.DEV.A.3	Nur wenn keine bereits entwickelte Software-Komponente geeignet ist, SOLLTE die Software-Komponente selbst erstellt werden. Dabei SOLLTE die Erstellung den Anforderungen in diesem Dokument folgen.
PROD.DEV.A.4	Es MÜSSEN die verbindlich dokumentierten Vorgaben bzgl. Codiernormen befolgt werden, die periodisch zu überprüfen und zu aktualisieren sind. Die Vorgaben MÜSSEN wenigstens beinhalten: • Keine Verwendung von Konstrukten, für die Informationssicherheitsprobleme bekannt bzw. zu erwarten sind, • Einsatz automatisierter Werkzeuge und Konfigurationen, • sichere Programmiertechniken, • Prüfung der Eingaben (bei Überschreitung der Vertrauensgrenze) und • Fehler-/Ausnahmebehandlung im Quellcode.
PROD.DEV.A.5	Die Software SOLLTE so entwickelt werden, dass „sichere“ Einstellungen voreingestellt sind (security by default). Diese Einstellungen MÜSSEN dokumentiert werden.
Weitere Informationen	NIST SP 800-218, Kapitel PW 62443-4-1, Kapitel 8 (SI)
Schlüsselworte	Codiernormen, Security by default, Dokumentation
Glossar	Fehlerbehandlung, Vertrauensgrenze

3.2.3.2 Entwurf

Im Entwurf (auch als Design bezeichnet) wird festgelegt, wie aus der spezifizierten Anforderungsanalyse (Anforderungskatalog / Requirements) eine Software erstellt werden kann. Die Anforderungen an die Informationssicherheit in diesem Prozess sind hier aufgeführt.

Tabelle 17 Anforderungen Produzent Entwicklung Entwurf

Anforderungs-ID	Anforderung
PROD.DEV.B.1	Der Software-Entwurf SOLLTE den Anforderungskatalog (vgl. Kapitel 3.2 Hinweis), das Sicherheitsprofil (Schutzbedarfe von Daten und Funktionen) und die Ergebnisse der Bedrohungsmodellierung (vgl. Kapitel 3.2.3.3) berücksichtigen.
PROD.DEV.B.2	Architektur- und Entwurfs-Entscheidungen SOLLTEN auf Basis von Prinzipien zum sicheren Design (siehe PROD.DEV.B.4) getroffen werden und im gesamten Software-Lebenszyklus beachtet und aufrechterhalten werden (security by design).
PROD.DEV.B.3	Es MUSS ein gesicherter Entwurf für jede Produktschnittstelle erstellt werden. Er MUSS beinhalten: • über die Schnittstelle erfolgende Kommunikation (z.B.

Anforderungs-ID	Anforderung
	Daten-/Kontrollflüsse), • absichernde Maßnahmen und • bei Angriffen betroffenen Objekte. Dabei SOLLTE auf Folgendes geachtet werden: • einen Hinweis, ob die Schnittstelle von außen (von anderen Produkten) oder von innen (von anderen Komponenten des Produkts) zugänglich ist oder ob beides zutrifft; • Informationssicherheitsauswirkungen des Informationssicherheitsumfelds des Produkts auf die externe Schnittstelle; • mögliche Benutzer der Schnittstelle und die Schutzobjekte, auf die darüber zugegriffen werden kann (direkt oder indirekt); • eine Bestimmung, ob der Zugriff auf die Schnittstelle eine Vertrauensgrenze überschreitet; • IT-Sicherheitsbetrachtungen, Annahmen und/oder Bedingungen im Zusammenhang mit der Nutzung der Schnittstelle innerhalb des IT-Sicherheitsumfelds des Produkts einschließlich zutreffender Bedrohungen; • die IT-Sicherheitsrollen, Berechtigungen/Rechte und Zugriffsberechtigungen, die für die Nutzung der Schnittstelle und für den Zugriff auf die vorgenannt angegebenen Schutzobjekte erforderlich sind; • die Fähigkeiten im Hinblick auf die IT-Sicherheit und/oder Kompensationsmechanismen zum Schutz der Schnittstelle und der vorgenannt festgelegten Schutzobjekte einschließlich der Validierung sowohl von Eingaben und Ausgaben und der Fehlerbehandlung; • die Nutzung von Fremdprodukten zur Implementierung der Schnittstelle und deren Fähigkeiten im Hinblick auf die IT-Sicherheit; • eine Dokumentation, die beschreibt, wie die Schnittstelle anzuwenden ist, wenn sie von außen zugänglich ist, und • eine Beschreibung, wie der Entwurf die im Bedrohungsmodell gekennzeichneten Bedrohungen abschwächt.
PROD.DEV.B.4	Der Entwurf einer Software MUSS (bzgl. Informationssicherheit) nach sicheren Entwurfs-Prinzipien durchgeführt werden, insbesondere: • Eingabevalidierung von Daten, vorzugsweise auf dem Server, • Least privilege, • Security by Default, • Schutz von Daten bei Fehlern und Ausfällen, • Schutz der Vertraulichkeit von Daten, • Nutzung von vertrauenswürdigen Verfahren und Implementierungen zum Schutz der Daten und Metadaten u.a. der Benutzer-Authentisierung und Authentifizierung, • Sicherheitsrelevante Ereignisse sind auswertbar zu protokollieren, • Für die Entwicklung relevante Informationen/ Kommentare SOLLTEN aus der Produktivversion entfernt werden, • Verkleinerung der Angriffsfläche, • Möglichkeit zur Behandlung von Fehlern und Exceptions (Ausnahmen) und • Privacy by design.

Anforderungs-ID	Anforderung
PROD.DEV.B.5	Wo möglich SOLLTE die Unterstützung für die Verwendung standardisierter Sicherheitsfunktionen und -diensten (z.B. Zugangskontrollsystemen) mittels entsprechender Schnittstellen vorgesehen werden.
PROD.DEV.B.6	Das Systemdesign MUSS dokumentiert werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 62443-4-1, Kapitel 7 (SD) NESAS, Kapitel [REQ-DES] NIST SP 800-218, Kapitel PW
Schlüsselworte	Security by design, security by default
Glossar	Privacy by design

3.2.3.3 Bedrohungsmodellierung

Die Bedrohungsmodellierung dient zur Analyse des zu entwickelnden Produktes bzgl. möglicher Bedrohungen. Sie ist die Grundlage für alle sicherheitsrelevanten Aspekte in den weiteren Aktivitäten im Entwicklungsprozess.

Tabelle 18 Anforderungen Produzent Entwicklung Bedrohungsmodellierung

Anforderungs-ID	Anforderung
PROD.DEV.C.1	In der Entwurfsphase der Software-Entwicklung MUSS eine Bedrohungsmodellierung durchgeführt werden. Hierzu SOLLTEN auf Basis des Sicherheitsprofils, des Anforderungskatalogs und der geplanten Einsatzumgebung bzw. Einsatzszenarios potentielle Bedrohungen identifiziert werden. Die Bedrohungen SOLLTEN hinsichtlich ihrer Eintrittswahrscheinlichkeit und Auswirkung bewertet werden.
PROD.DEV.C.2	Das Bedrohungsmodell MUSS folgende Aspekte berücksichtigen (sofern anwendbar): • die Datenflüsse schutzbedürftiger Informationen, • Vertrauensgrenzen, • Prozesse, • Datenspeicher, • Wechselwirkung mit externen Komponenten oder Systemen, von denen die IT-Sicherheit des Produkts abhängt, • interne und externe Kommunikationsprotokolle, die im Produkt implementiert sind, • Debug-Schnittstellen, • mögliche Bedrohungen und deren Schweregrad nach einer Festlegung durch ein Verwundbarkeitsbewertungssystem (z. B. CVSS), • Abschwächungsmaßnahmen und/oder Behandlung jeder Bedrohung, • ermittelte sicherheitsbezogene Probleme und • äußere Abhängigkeiten in Form von Treibern oder Fremdanwendungen

Anforderungs-ID	Anforderung
	(nicht vom Hersteller entwickelter Code), die mit der Anwendung/dem Produkt verknüpft werden.
PROD.DEV.C.3	Das Bedrohungsmodell MUSS seitens des Entwicklungsteams hinsichtlich Korrektheit und Verständnis geprüft werden.
PROD.DEV.C.4	Das Bedrohungsmodell MUSS regelmäßig oder anlassbezogen für Produkte, die im Einsatz sind, geprüft und auf einen aktuellen Stand gebracht werden.
PROD.DEV.C.5	Alle Ergebnisse/Befunde der Bedrohungsmodellierung MÜSSEN bewertet und behandelt werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 62443-4-1, Kapitel 6 (SR) NESAS, Kapitel [REQ-DES] NIST SP 800-218, Kapitel PW
Schlüsselworte	Bedrohungsmodell, Sicherheitsprofil
Glossar	Sicherheitsprofil

3.2.3.4 Entwurf – Software-Architektur

In der Software-Architektur, als Teil des Software-Entwurfs, werden die Strukturen des späteren Softwaresystems definiert. Diese dient als Grundlage für die weiteren Prozessschritte, in denen eine Anpassung der Architektur erfolgen kann.

Tabelle 19 Anforderungen Produzent Entwicklung Entwurf

Anforderungs-ID	Anforderung
PROD.DEV.D.1	Im Rahmen des sicheren Software-Entwurfs SOLLTE eine sichere Software-Architektur entwickelt werden.
PROD.DEV.D.2	Es MÜSSEN sichere Software-Architektur-Prinzipien verwendet werden (security by design), wie z.B. Domain separation, Encapsulation, Layering.
PROD.DEV.D.3	Es MUSS eine Schichtung (Layering) erfolgen, die auf einer Risikoabwägung basiert und die, sofern vorhanden, das Bedrohungsmodell berücksichtigt. Jede Schicht MUSS einen Informationssicherheitsmechanismus/Instanz bereitstellen.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 NESAS, Kapitel [REQ-DES] 62443-4-1, Kapitel 7 (SD)
Schlüsselworte	Domain separation, Encapsulation, Layering, security by design
Glossar	Defense in Depth, domain separation, encapsulation, layering

3.2.3.5 Entwurfsprüfung

Hier wird der Entwurf auf die Einhaltung von Informationssicherheitsanforderungen geprüft.

Tabelle 20 Anforderungen Produzent Entwicklung Entwurfsprüfung

Anforderungs-ID	Anforderung
PROD.DEV.E.1	Der Entwurf MUSS überprüft werden, ob alle festgelegten Sicherheitsanforderungen an das Systemdesign erfüllt wurden. Dazu zählen u.a.: • die Nennung der durch den Entwurf ausreichend und nicht ausreichend betrachteten Sicherheitsanforderungen, • die Betrachtung von Bedrohungen und wie sich diese der vorhandenen Schnittstellen bedienen, • die Dokumentation, in wie weit bewährte Designprinzipien (vgl. „Entwurf“ oben) nicht beachtet wurden.
PROD.DEV.E.3	Das Design MUSS durch eine Person, die nicht am Entwurf beteiligt war, und/oder mittels automatisiertem Werkzeug geprüft werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 NIST SP 800-218, Kapitel PW 62443-4-1, Kapitel 7 (SD)
Schlüsselworte	Design, Review, Prüfen
Glossar	-

3.2.3.6 Entwicklungsbegleitende Tests

Entwicklungsbegleitende Tests werden während der Implementierung durchgeführt, um Fehler in der Umsetzung (Code) möglichst frühzeitig zu erkennen.

Tabelle 21 Anforderungen Produzent Entwicklungsbegleitende Tests

Anforderungs-ID	Anforderung
PROD.DEV.F.1	Grundlage für die entwicklungsbegleitenden Tests MÜSSEN die definierten Dokumentationen zu verbindlichen Vorgaben sein.
PROD.DEV.F.2	Es MÜSSEN entwicklungsbegleitende Software-Tests durchgeführt und u.a. der Quellcode auf Fehler gesichtet werden (z.B. mittels code review). Hierbei SOLLTEN bereits die Fachverantwortlichen des Auftraggebers oder der beauftragenden Fachabteilung beteiligt werden. Die entwicklungsbegleitenden Tests MÜSSEN • die funktionalen und nichtfunktionalen Anforderungen der Software umfassen, • dabei auch Negativtests abdecken, • zusätzlich auch alle kritischen Grenzwerte der Eingabe sowie der Datentypen überprüfen, • nicht beachtete Codierungsnormen kennzeichnen und

Anforderungs-ID	Anforderung
	untersuchen, inwiefern die Implementierung gegen die Bedrohungen ausreichend geschützt ist. Testdaten SOLLTEN dafür sorgfältig ausgewählt und geschützt werden. Darüber hinaus SOLLTE eine automatische statische Codeanalyse durchgeführt werden. Die Software MUSS in einer Test- und Entwicklungsumgebung getestet werden, die getrennt von der Produktionsumgebung ist. Außerdem MUSS getestet werden, ob die Systemvoraussetzungen für die vorgesehene Software ausreichend dimensioniert sind.
PROD.DEV.F.3	Erkenntnisse, die sich durch entwicklungsbegleitende Tests ergeben, MÜSSEN dokumentiert und nachverfolgt werden.
Weitere Informationen	IT-Grundschutz-Kompodium, Baustein CON.8 NESAS, Kapitel [REQ-IMP] NIST SP 800-218, Kapitel PW 62443-4-1, Kapitel 8 (SI)
Schlüsselworte	Code Review, statische und dynamische Codeanalyse, Dokumentation, Testdaten
Glossar	-

3.2.3.7 Drittkomponenten

Der Einsatz von Drittkomponenten ermöglicht die Nutzung von bereits implementierten Funktionalitäten aus externen und internen Quellen, was jedoch zusätzliche Risiken birgt. Komponenten können z.B. Frameworks, Middleware, Bibliotheken, Module sein.

Tabelle 22 Anforderungen Produzent Entwicklung Drittkomponenten

Anforderungs-ID	Anforderung
	Bei der Verwendung von Drittkomponenten sind folgende Aspekte zu berücksichtigen:
PROD.DEV.G.1	Sie MÜSSEN aus einer vertrauenswürdigen Quelle⁴ stammen.
PROD.DEV.G.2	Ihre Integrität MUSS vor der Verwendung durch Prüfsummen oder kryptographische Zertifikate sichergestellt werden.
PROD.DEV.G.3	- Informationssicherheitsrisiken MÜSSEN kenntlich gemacht und behandelt werden (Stichwort: sichere Lieferkette). - Unbekannte externe Komponenten (bzw. Programm-Bibliotheken), deren Sicherheit nicht durch etablierte und anerkannte Peer-Reviews oder vergleichbares sichergestellt werden kann, MÜSSEN auf Schwachstellen überprüft werden.

⁴) Jede Institution sollte prüfen und festlegen, welche internen, externen Quellen (z. B. Downloadseite vom Hersteller oder Original-Installationsmedium) als vertrauenswürdig erachtet werden. Hierbei sollte der individuelle Schutzbedarf berücksichtigt werden (ISMS).

Anforderungs-ID	Anforderung
	Alle externen Komponenten MÜSSEN auf potentielle Konflikte überprüft werden.
PROD.DEV.G.4	Sie MÜSSEN, sofern beauftragt und auf die Informationssicherheit wirkend, bzgl. des Entwicklungszyklus mit den Anforderungen dieses Dokuments übereinstimmen.
PROD.DEV.G.5	Sie MÜSSEN über ihren gesamten Lebenszyklus die Informationssicherheitsanforderungen des Herstellers erfüllen.
PROD.DEV.G.6	Es SOLLTEN keine veralteten Versionen von Drittkomponenten verwendet werden.
PROD.DEV.G.7	Die Verwendung von Drittkomponenten, die nicht mehr gepflegt werden, SOLLTE vermieden werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 NESAS, Kapitel [REQ-GEN] NIST SP 800-218, Kapitel PW, PO 62443-4-1, Kapitel 5 (SM)
Schlüsselworte	Drittkomponenten, Integrität, sichere Lieferkette
Glossar	-

3.2.3.8 Code Management

Das Code Management dient zur Verwaltung des Programmcodes.

Tabelle 23 Anforderungen Produzent Entwicklung Code Management

Anforderungs-ID	Anforderung
PROD.DEV.H.1	Der Quellcode des Entwicklungsprojekts MUSS über eine geeignete Versionsverwaltung verwaltet werden. Hierzu sind insbesondere folgende Aspekte zu beachten: - Der Zugriff auf die Versionsverwaltung MUSS geregelt und festgelegt werden. - Es MUSS festgelegt werden, wann Änderungen am Quellcode als eigene Version in der Versionsverwaltung gespeichert werden sollen. - Alle Änderungen MÜSSEN nachvollzogen und rückgängig gemacht werden können. - Die Versionsverwaltung inkl. der Daten MUSS Bestandteil eines Datensicherungskonzept sein und DARF NICHT ohne Datensicherung erfolgen.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 NESAS, Kapitel [REQ-IMP] NIST SP 800-218, Kapitel PS
Schlüsselworte	Versionsverwaltung, Quellcode, Datensicherung

Anforderungs-ID	Anforderung
Glossar	-

3.2.3.9 Compiler, Interpreter und Build-Werkzeuge

Im Rahmen der Software-Entwicklung werden Werkzeuge genutzt, die an unterschiedlichen Stellen den Entwicklungsprozess unterstützen. Anforderungen an Werkzeuge im Implementierungskontext sind wie folgt dargestellt.

Tabelle 24 Anforderungen Produzent Compiler, Interpreter und Build-Werkzeuge

Anforderungs-ID	Anforderung
PROD.DEV.I.1	Es MÜSSEN Werkzeuge (Compiler-, Interpreter- und Build-Tools) benutzt werden, die Merkmale zur Verbesserung der Informationssicherheit des zu produzierenden Codes anbieten.
PROD.DEV.I.2	Die in den benutzten Werkzeugen enthaltenen Möglichkeiten zur Verbesserung der Informationssicherheit MÜSSEN implementiert und genutzt werden.
PROD.DEV.I.3	Der Hersteller MUSS ein automatisiertes Build Tool verwenden, um reproduzierbare Builds zu erstellen und die Build Logs speichern.
PROD.DEV.I.4	Jegliche Daten, die in der Build-Umgebung verwendet werden um einen Build zu generieren, MÜSSEN aus einem VCS (version control system) stammen. Dies stellt die Reproduzierbarkeit sicher.
Weitere Informationen	NIST SP 800-218, Kapitel PW NESAS, Kapitel [REQ-BUI]
Schlüsselworte	Werkzeuge, Versionskontrolle
Glossar	Build Tool

3.2.3.10 Inventarisierung

Die Inventarisierung dient der Bestandsaufnahme der Komponenten einer Software und zugehöriger Informationen.

Tabelle 25 Anforderungen Produzent Entwicklung Inventarisierung

Anforderungs-ID	Anforderung
PROD.DEV.L.1	Für jedes Softwarerelease MÜSSEN die notwendigen Dateien und Informationen (z.B. integritätssichernde Informationen und Auskünfte zur Herkunft ggf. verwendeter externer Komponenten) sicher archiviert werden.
PROD.DEV.L.2	Herkunftsnachweise verwendeter Komponenten MÜSSEN gesammelt und in Übereinstimmung mit der Herstellerpolicy/Compliance Dritten bereitgestellt werden (z.B. als SBOM).
Weitere Informationen	NIST SP 800-218, Kapitel PS

Anforderungs-ID	Anforderung
	BSI TR-03183
Schlüsselworte	Archivierung, SBOM
Glossar	SBOM

3.2.4 Test und Freigabe

In diesem Prozess wird die erstellte Software abschließend mit dem Ziel der Freigabe geprüft. Dabei sind die folgenden Anforderungen zu berücksichtigen.

Tabelle 26 Anforderungen Produzent Entwicklung Test und Freigabe

Anforderungs-ID	Anforderung
PROD.TEST.A.1	Die Rahmenbedingungen für Software-Tests MÜSSEN vor den Tests festgelegt werden. Berücksichtigt werden MÜSSEN: • innerhalb der Institution geltende Schutzbedarfe, Organisationseinheiten, technischen Möglichkeiten und Testumgebungen. • Anforderungen des Anforderungskatalogs. Liegt auch ein Pflichtenheft vor, dann MUSS dieses zusätzlich berücksichtigt werden. • Auswahl der Testfälle, sodass diese möglichst repräsentativ alle Funktionen der Software überprüfen. Zusätzlich MÜSSEN auch Negativ-Tests berücksichtigt werden. • Die Tests MÜSSEN eine Prüfung auf bereits bekannte Schwachstellen beinhalten. • Auswahl der Testumgebung, sodass diese die IT-Infrastruktur in der spezifizierten Einsatzumgebung abdeckt.
PROD.TEST.A.2	Bei der Entscheidung, welche Informationssicherheitsbezogene Tests erfolgen sollen, MÜSSEN die Informationssicherheitsanforderungen und das Bedrohungsmodell (vgl. Kapitel 3.2.3.3) einbezogen werden
PROD.TEST.A.3	Ferner SOLLTE schriftlich festgelegt werden: • die erwarteten Test-Ergebnisse, • die Freigabekriterien, • und eine Vorgehensweise für die Situation, wenn eine Freigabe abgelehnt wird.
PROD.TEST.A.4	Bei der Auswahl der Software-Tester SOLLTEN folgende Auswahlkriterien berücksichtigt werden: • Die Software-Tester SOLLTEN die erforderliche berufliche Qualifikation haben. • Wird Software auf Quellcode-Ebene überprüft, dann SOLLTEN die Tester über ausreichendes Fachwissen über die zu testenden Programmiersprache und der Entwicklungsumgebung verfügen.

PROD.TEST.A.5	Die Rollen „Entwickler“ und „Tester“ SOLLTEN personell getrennt sein.
PROD.TEST.A.6	Der Fachverantwortliche SOLLTE die Software-Tester informieren über • die durchzuführenden Testarten und die zu testenden Bereiche einer Software sowie • die Anwendungsfälle und mögliche weitere Anforderungen der Software.
PROD.TEST.A.7	Sofern Testende auf besonders schützenswerte Informationen zugreifen müssen, KANN es z.B. sinnvoll sein, dass die Institution Nachweise über ihre Integrität und Reputation einholt. Hierzu SOLLTE der oder die ISB, die Geheimschutzbeauftragten bzw. Sicherheitsbevollmächtigten der Institution einbeziehen.
PROD.TEST.A.8	Die entwickelte Software MUSS auf Basis der in der Planung festgelegten Rahmenbedingungen getestet werden.
PROD.TEST.A.9	Werden Testfälle ausgelassen, SOLLTE dies begründet und dokumentiert werden.
PROD.TEST.A.10	Wenn Produktivdaten für Software-Tests verwendet werden, die schützenswerte Informationen enthalten, dann MÜSSEN diese Testdaten angemessen geschützt werden. Enthalten diese Daten personenbezogene Informationen, dann MÜSSEN diese Daten mindestens pseudonymisiert werden.
PROD.TEST.A.11	Die entwickelte Software SOLLTE nur in einer hierfür vorgesehenen Testumgebung getestet werden. Die Testumgebung SOLLTE von der Produktivumgebung getrennt betrieben werden. Die in der Testumgebung verwendeten Architekturen und Mechanismen SOLLTEN dokumentiert werden. Es SOLLTEN Verfahren dokumentiert werden, wie mit der Testumgebung nach Abschluss des Software-Tests zu verfahren ist.
PROD.TEST.A.12	Die Installation der erstellten Software SOLLTE entsprechend der Regelungen zur Installation und Konfiguration überprüft werden. Es SOLLTE zusätzlich die Installations- und Konfigurationsdokumentation geprüft werden.
PROD.TEST.A.13	Mit funktionalen Software-Tests MUSS die ordnungsgemäße und vollständige Funktion der Software überprüft werden.
PROD.TEST.A.14	Es MÜSSEN Software-Tests durchgeführt werden, die überprüfen, ob alle wesentlichen nicht-funktionalen Anforderungen erfüllt werden. Insbesondere MÜSSEN sicherheitsspezifische Software-Tests durchgeführt werden, wenn die entwickelte Software sicherheitskritische Funktionen mitbringt.
PROD.TEST.A.15	Für entwickelte Software SOLLTEN Penetrationstests als Testmethode nach dem festgelegten Konzept durchgeführt werden. Im Konzept für Penetrationstests SOLLTEN neben den zu verwendenden Testmethoden auch die Erfolgskriterien dokumentiert werden. Die durch den Penetrationstest aufgefundenen Schwachstellen SOLLTEN

	klassifiziert und dokumentiert sein.
PROD.TEST.A.1 6	Die Ergebnisse der Software-Tests MÜSSEN ausgewertet und dokumentiert werden. Es SOLLTE ein Soll-Ist-Vergleich mit definierten Vorgaben durchgeführt werden.
PROD.TEST.A.1 7	Die fachlich zuständige Organisationseinheit MUSS überprüfen, ob die Software gemäß den Anforderungen getestet wurde und die Software freigeben, sobald - die Software-Tests erfolgreich* durchgeführt wurden (*für einen erfolgreichen Software-Test MÜSSEN die Ergebnisse mit den vorher festgelegten Erwartungen übereinstimmen) und - alle sicherheitsbezogenen Probleme abschließend behandelt wurden. Die Freigabe MUSS dokumentiert werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein OPS.1.1.6 62443-4-1, Kapitel 5 (SM) und Kapitel 9 (SVV) NIST SP 800-218, Kapitel PW NESAS, Kapitel [REQ-TES]
Schlüsselworte	Test, Negativ-Test, Freigabe, Dokumentation, Bedrohungsmodell, Testumgebung, Rollentrennung, Qualifikation, Penetrationstest
Glossar	-

3.2.4.1 Patches und Updates

Tabelle 27 Anforderungen Produzent Test und Freigabe für Patches- und Updates

Anforderungs-ID	Anforderung
PROD.TEST.D.1	Wenn Software verändert wurde, SOLLTEN Regressionstests durchgeführt werden. Hierbei SOLLTE überprüft werden, ob bisherige bestehende Sicherheitsmechanismen und -einstellungen durch das Update ungewollt verändert wurden. Regressionstests SOLLTEN vollständig durchgeführt werden und hierbei auch Erweiterungen (z.B. PlugIns, AddOns) sowie Hilfsmittel (z.B. Wartungsroutinen) umfassen.
PROD.TEST.D.2	Regressionstest betreffen Updates des Herstellers, Updates von Drittkomponenten im Produkt und Updates zu anderweitiger Komponenten oder Plattformen, von denen das Produkt abhängig ist. Ferner SOLLTE geprüft werden, dass die Anwendung des Updates keinen sonstigen Sachzwängen bzw. Beschränkungen widerspricht.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein OPS.1.1.6 62443-4-1, Kapitel 11 (SUM)
Schlüsselworte	Update, Test, Regressionstest
Glossar	update

3.2.5 Auslieferung

Getestete und freigegebene Software (neu erstellte und Updates/Patches) kann bereitgestellt/ausgeliefert werden.

Tabelle 28 Anforderungen Produzent Auslieferung

Anforderungs-ID	Anforderung
PROD.REL.1	Für die Auslieferung von Software MUSS vom Hersteller ein Mechanismus zur Integritätssicherung (z.B. Checksummen, digitale Signaturen) bereitgestellt werden.
PROD.REL.2	Jedes Software Release MUSS mittels einer eindeutigen Versionsnummer einer spezifischen Buildversion zugeordnet werden können.
	HINWEIS: Speziell im Kontext der Auslieferung von Patches stellen sich weitere Anforderungen, die im Prozess „Schwachstellenmanagement“ weiter erörtert werden.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 62443-4-1, Kapitel 5 (SM) NESAS, Kapitel [REQ-REL] NIST SP 800-218, Kapitel PS
Schlüsselworte	Integritätssicherung, Auslieferung, Versionsnummer
Glossar	-

3.2.6 Schwachstellenmanagement

In (Software-)Produkten können Fehler auftauchen, die Sicherheitsprobleme durch Schwachstellen hervorrufen.

Werden sicherheitskritische Schwachstellen in der eigenentwickelten Software erkannt, müssen zeitnah Lösungen (z.B. Patches/Updates) bereitgestellt werden.

Werden Lösungen zu sicherheitskritischen Schwachstellen in Drittkomponenten durch deren Hersteller/Ersteller bereitgestellt, muss die eigenentwickelte Software ggf. entsprechend angepasst und zeitnah als Lösung zur Verfügung gestellt werden.

Hier werden Anforderungen zur Behandlung sicherheitsbezogener Probleme eines Produkts beschrieben.

Tabelle 29 Anforderungen Produzent Schwachstellenmanagement

Anforderungs-ID	Anforderung
PROD.FIX.A.1	Neben bereits vorhandener Dokumentation MUSS eine Dokumentation erstellt werden, die Zeitfenster für eine Bereitstellung von IT-Sicherheitsupdates (z.B. zeitnah) festlegt. Eine Bereitstellung umfasst die Qualifizierung auf Zielerreichung und Lieferung. Hierbei ist mindestens zu berücksichtigen: • mögliche Auswirkungen der Schwachstelle,

Anforderungs-ID	Anforderung
	• die öffentliche Kenntnis der Schwachstelle, • ob veröffentlichte Exploits für die Schwachstelle vorhanden sind, • den Umfang der eingesetzten Produkte, die betroffen sind und die Verfügbarkeit wirksamer Abschwächungsmaßnahmen anstelle eines Patches. Es SOLLTE eine Unterscheidung der Auslieferwege zwischen normalen Updates und IT-Sicherheits-Updates erfolgen. Die Befolgung der in der Dokumentation festgelegten Aspekte MUSS sichergestellt werden.
PROD.FIX.A.2	Das Produkt MUSS beim Bekanntwerden von Schwachstellen auf ähnliche/vergleichbare Schwachstellen geprüft werden, um diese proaktiv zu behandeln anstatt nur auf externe Meldungen zu reagieren.
PROD.FIX.A.3	Es MUSS eine Meldestelle für informationssicherheitsbezogene Probleme des Produktes existieren und kommuniziert werden Es MUSS eine Verfolgung/Abarbeitung der Meldungen (aus internen und externen Quellen) durch ein Verfahren sichergestellt.
PROD.FIX.A.4	Es MUSS mittels aktiver Recherche und entsprechenden Aktionen sichergestellt sein, dass bereits entdeckte sicherheitskritische Schwachstellen im eigenen Produkt sowie in verwendeten Bibliotheken/Software von Drittanbietern bemerkt werden (z.B. Eigenrecherche). Die eigene Software MUSS auf Anfälligkeit gegenüber diesen Schwachstellen geprüft werden.
PROD.FIX.A.5	Es MUSS das eigene Produkt auf eventuell bisher nicht entdeckte sicherheitskritische Schwachstellen geprüft werden. Die Ursachen müssen gefunden werden und sind auch über die Zeit zu betrachten, um mögliche Muster (z.B. Nicht-Beachtung von verbindlichen Kodiervorgaben) zu finden.
PROD.FIX.A.6	Gemeldete informationssicherheitsbezogene Probleme MÜSSEN in einem festzulegenden Verfahren rechtzeitig⁵ untersucht werden, wobei festzustellen ist • ihre Anwendbarkeit für das Produkt, • Verifizierbarkeit und • Bedrohungen, die das Problem auslösen.
PROD.FIX.A.7	Es MUSS eine Analyse informationssicherheitsbezogener Probleme im Produkt in einem festzulegenden Verfahren durchgeführt werden, mit Fokus auf: • die Bewertung ihrer Auswirkung in Bezug auf: ○ das tatsächliche IT-Sicherheitsumfeld, in dem sie festgestellt wurden ○ das IT-Sicherheitsumfeld des Produkts und ○ die gestaffelte Sicherheits-Strategie des Produkts • Festlegung des Schweregrads (wie durch ein Verwundbarkeitsbewertungssystem (z. B. CVSS)); • Identifizierung aller ebenfalls vom sicherheitsbezogenen Problem betroffenen Produkte/Produktversionen;

⁵ Die Rechtzeitigkeit/Zeitnähe wird von den Marktgegebenheiten vorgegeben

Anforderungs-ID	Anforderung
	Nennung der Grundursache des Problems und weiterer zugehöriger IT-Sicherheitsprobleme.
PROD.FIX.A.8	Probleme mit Bezug zur Informationssicherheit MÜSSEN in einem Verfahren bearbeitet/behandelt werden. Dabei MUSS auf Basis der Analyse geregelt werden, ob eine Meldung/Offenlegung⁶ des Problems erfolgen soll. Es MUSS ein akzeptables Restrisiko-Niveau festgelegt werden, dass bei der Bearbeitung des Problems erreicht wird. Mögliche Bearbeitungsformen des Problems sind ein oder mehrere der Folgenden: - Behebung (Patch/Codeänderung), - Erstellung eines Plans zur Behebung, - Verschieben in eine zukünftige Lösung/Version oder - Nichtbeheben des Problems, sofern das Restrisiko akzeptabel erscheint. Es MÜSSEN - andere (relevante) Verfahren über das Problem informiert werden. Sowohl bzgl. des eigentlichen als auch weiterer Produkte. - Drittanbieter informiert werden, falls die Probleme deren eingebundenen Quellcode betreffen. Werden Probleme gelöst, SOLLEN Empfehlungen zur zukünftigen Problemvermeidung daraus resultieren. Das Verfahren MUSS eine regelmäßige Überprüfung (mindestens während jedes Freigabe- oder Iterationszyklus) von offenen sicherheitsbezogenen Problemen umfassen.
PROD.FIX.A.9	Es MUSS ein Verfahren bestehen, sodass zu meldende Informationssicherheitsbezogene Probleme im Produkt und die vom Hersteller vorgesehene Lösung (Behebung, Mängelbeseitigungsplan, Verschieben in zukünftige Lösung, Nichtbeheben) den Anwendern rechtzeitig⁷ bereit gestellt werden. Das Verfahren SOLLTE bzgl. einer Offenlegung von Problemen in Drittkomponenten eine diesbezügliche Abstimmung zur Verfahrensweise mit dem (Drittkomponenten-)Hersteller beinhalten.
PROD.FIX.A.10	Den Anwendern MUSS eine Dokumentation über IT-Sicherheits-Updates für das Produkt zur Verfügung gestellt werden, die unter anderem das Folgende enthält: - die Versionsnummer(n) des Produkts, für die der Patch gilt, - Anweisungen, wie Patches manuell oder mit einem automatisierten Prozess anzuwenden sind, - eine Beschreibung aller Auswirkungen, die die Anwendung des Patches auf das Produkt nach sich zieht, einschließlich eines Neustarts, - Anweisungen, wie nachzuweisen ist, dass ein Patch angewendet worden ist und - Risiken, die dadurch entstehen, dass der Patch nicht verwendet wird oder nicht vom Entwickler freigegeben ist.
PROD.FIX.A.11	Den Anwendern MUSS eine Dokumentation über IT-Sicherheits-Updates für

⁶ Meldepflichtige Lösungen sind in der Regel solche, die sich auf freigegebene Produkte beziehen, bei denen der Schweregrad des Problems als so hoch angesehen wird, dass sie vom Hersteller gemeldet/offengelegt werden.

⁷ Die Rechtzeitigkeit/Zeitnähe wird von den Marktgegebenheiten vorgegeben

Anforderungs-ID	Anforderung
	abhängige Komponenten oder Betriebssysteme zur Verfügung gestellt werden, die unter anderem eine Angabe • ob das Produkt mit dem IT-Sicherheits-Update für die abhängige Komponente oder das Betriebssystem kompatibel ist und • bei IT-Sicherheits-Updates, die vom Produktanbieter nicht freigegeben sind, die Abschwächungsmaßnahmen, die angewendet werden, wenn das Update nicht eingesetzt wird, enthält.
Weitere Informationen	IT-Grundschutz-Kompendium, Baustein CON.8 62443-4-1, Kapitel 10 (DM) und 11 (SUM) NESAS, Kapitel [REQ OPE] NIST SP 800-218, Kapitel RV BSI TR-03191 CSAF CVD-Prozess, Leitlinie des BSI
Schlüsselworte	Auslieferwege, IT-Sicherheitsupdate, Lösung, Meldestelle, Patch, Schwachstelle
Glossar	IT-Sicherheitsupdate, Lösung, Patch, Schwachstelle

3.2.7 Außerbetriebnahme

Wird eine Software abgekündigt und nicht weiter vom Hersteller unterstützt, sind auch Aspekte aus Sicht der Informationssicherheit zu beachten.

Tabelle 30 Anforderungen Produzent Außerbetriebnahme

Anforderungs-ID	Anforderung
PROD.DECOM.1	Die Außerbetriebnahme des Produktes bzw. diesbezügliche Regelungen MÜSSEN in einer Benutzerdokumentation beschrieben sein. Diese muss Erläuterungen zur Deinstallation der Software und Entfernung der verwendeten/gespeicherten Daten enthalten.
PROD.DECOM.2	Die Nutzer SOLLTEN über die Abkündigung der Software und den Zeitpunkt informiert werden, ab dem die Unterstützung/Support durch den Hersteller eingestellt werden. Über mögliche Migrationspfade SOLLTEN die Benutzer informiert werden.
PROD.DECOM.3	Die für das Produkt verwendeten Entwicklungs-Werkzeuge SOLLTEN bereinigt/aufgeräumt werden. So SOLLTEN z.B. alle nicht mehr benötigten Zugriffsrechte auf die Produktinformationen (z.B. Quellcode, Skripte, Designdokumente, Anforderungskatalog) entzogen werden.
Weitere Informationen	62443-4-1, Kapitel 12 (SG)
Schlüsselworte	Benutzerdokumentation, Außerbetriebnahme
Glossar	-

Anforderungs-ID	Anforderung

Glossar

Tabelle 31 Glossar

Begriff	Erläuterung
Build tool	Ein Programm zum automatisierten Erzeugen von Software. (Quelle: https://www.heise.de/hintergrund/Continuous-Integration-mit-Java-und-JavaScript-2853319.html?seite=2)
Domain separation	Domäne: Ansammlung von Daten und Anweisungen Domain Separation: Die Trennung von Domänen ermöglicht eine Kontrolle über Zugriff und Nutzung dieser Sammlungen. Quelle: (https://mlhale.github.io/nebraska-gencyber-modules/intro_to_first_principles/README/)
Encapsulation	Als Datenkapselung (englisch encapsulation) wird in der Programmierung das Verbergen von Daten oder Informationen vor dem Zugriff von außen bezeichnet. Der direkte Zugriff auf die interne Datenstruktur wird unterbunden und erfolgt stattdessen über definierte Schnittstellen (Black-Box-Modell). Quelle: https://de.wikipedia.org/wiki/Datenkapselung_(Programmierung)
Fachverantwortliche	Fachverantwortliche sind inhaltlich für ein oder mehrere Geschäftsprozesse oder Fachverfahren zuständig. (Quelle: BSI Grundschutz-Kompendium, 2023)
Fehlerbehandlung	Vorkehrungen im Quellcode, die zum Zeitpunkt der Entwicklung getroffen werden, um mit Fehlern und Meldungen, die zur Laufzeit „von Außen“ an das „Programm“ zurückgemeldet werden, adäquat umzugehen.
FLOSS	Free, Libre, Open Source Software; siehe BSI-Seite im Internet
Gestaffelte Sicherheitsstrategie/Defense-in-Depth-Strategie	Ansatz zur Verteidigung des Systems gegen einen beliebigen bestimmten Angriff mit Anwendung mehrerer unabhängiger Methoden (Quelle: DIN EN IEC 62443-4-1, Ziffer 3.1.15)
IT-Sicherheits-Update	Zur Auslieferung aufbereitete Lösung, Summe der Maßnahmen aus Herstellersicht, die einem Anwender zur Behebung einer Schwachstelle zur Verfügung gestellt wird. Die Entscheidung zur Behebung zieht immer eine Codeänderung (Patch) nach sich.
Layering	In der Programmierung ist das Layering die Organisation der Programmierung in separate funktionale Komponenten, die in einer sequenziellen und hierarchischen Weise interagieren, wobei jede Schicht normalerweise nur eine Schnittstelle zur darüber liegenden und zur darunterliegenden Schicht hat. (Quelle: https://www.computerweekly.com/de/definition/Layering-Schichten)
Lösung (zur	Ansatz/Maßnahmen(bündel) aus Herstellersicht, um einer akzeptierten Schwachstelle

Begriff	Erläuterung
Schwachstelle)	zu begegnen. Kann gegenüber einer seitens Kunden erwarteten Lösung differieren.
Patch	Ein Patch ist eine Fehlerbehebung für ausführbare Programme, er kann auch kleinere Funktionserweiterungen enthalten. Ein Patch beinhaltet i.d.R. eine Codeänderung, inkl. ggf. notwendiger Informationen (z.B. Dokumentation, Konfigurationsdatei). (Quelle: https://de.wikipedia.org/wiki/Patch_(Software))
Privacy by Design	Während „Privacy by Design“ vor allem den Schutz der Privatsphäre meint und damit vor allem darauf zielt, dass bestimmte Datenverarbeitungen überhaupt nicht stattfinden, umfasst „Data Protection by Design“ auch solche Datenverarbeitungen, die tatsächlich stattfinden und auch legitim sind. (Quelle: https://www.bfdi.bund.de/DE/Fachthemen/Inhalte/Technik/DPbD.html)
SBOM	Software Bill of Material, Software-Stückliste: Eine "Software Bill of Materials" (SBOM) ist eine maschinenverarbeitbare Datei, die Lieferkettenbeziehungen und Details zu den in einem Software-Produkt verwendeten Komponenten enthält. Sie unterstützt die automatische Verarbeitung von Informationen über Software-Komponenten. Dies umfasst sowohl die so genannte "Primärkomponente" als auch verwendete (Dritt-)Komponenten. (Quelle: https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TR03183/BSI-TR-03183-2.pdf?__blob=publicationFile&v=5)
Schutzbedarf	Der Schutzbedarf eines Objekts bezüglich der betrachteten Grundwerte (z.B. Verfügbarkeit, Integrität, Vertraulichkeit) orientiert sich an dem Ausmaß des bei Verletzungen der Grundwerte jeweils drohenden Schadens. Der Schutzbedarf lässt sich nicht quantifizieren.
Schwachstelle	Eine Schwachstelle ist ein sicherheitsrelevanter Fehler eines IT-Systems oder einer Institution. Ursachen können in der Konzeption, den verwendeten Algorithmen, der Implementation, der Konfiguration, dem Betrieb sowie der Organisation liegen. Eine Schwachstelle kann dazu führen, dass eine Bedrohung wirksam wird und eine Institution oder ein System geschädigt wird. Durch eine Schwachstelle wird ein Objekt (eine Institution oder ein System) anfällig für Bedrohungen.
Sicherheitsprofil	Schutzbedarfe von Daten und Funktionen hinsichtlich Vertraulichkeit, Integrität und Verfügbarkeit.
technische Schulden	Kosten für zusätzliche Nachbesserungen infolge der Entscheidung für eine schnelle statt einer effektiven Lösung. (Quelle: https://asana.com/de/resources/technical-debt)
Vertrauensgrenze	Eine Grenze an der Daten die Vertrauensstufe wechseln. Beispiel: Der Empfang von Daten aus nicht geprüfter Quelle wie Benutzereingabe oder durch Netzwerksendung. (Quelle: https://en.wikipedia.org/wiki/Trust_boundary)
Vorgehensmodell	Vorgehensmodelle (z.B. Wasserfallmodell, V-Modell, agile Entwicklung) strukturieren und planen den Ablauf der Software-Entwicklung, indem bestimmte Handlungsschritte und deren Abfolge vorgegeben werden. (Quelle: IT-GS CON.8: Software-Entwicklung)

Literaturverzeichnis

62443-4-1: DIN EN IEC, „IT-Sicherheit für industrielle Automatisierungssysteme - Teil 4-1: Anforderungen an den Lebenszyklus für eine sichere Produktentwicklung (DIN EN IEC 62443-4-1:2018),“ International Electrotechnical Commission, 2018.

BSI TR-03183: BSI, „Cyber Resilience Requirements for Manufacturers and Products – Part 2: Software Bill of Materials (SBMO) Version 1.1“, Bundesamt für Sicherheit in der Informationstechnik, 28.11.2023.

BSI TR-03191: BSI, „Common Security Advisory Framework (CSAF)“, Version 1.0.1, Bundesamt für Sicherheit in der Informationstechnik, 2024.

CVD-Prozess: BSI, „Leitlinie des BSI zum Coordinated Vulnerability Disclosure (CVD)-Prozess Version 1.0,“ Bundesamt für Sicherheit in der Informationstechnik, 2022.

Cyber Resilience Act: EU, „Cyber Resilience Act,“ Europäische Kommission, 2022.

IT-Grundschutz-Kompendium: BSI, „IT-Grundschutz-Kompendium,“ Bundesamt für Sicherheit in der Informationstechnik, 2023.

NESAS: GSMA, „Development and Lifecycle Security Requirements FS.16, Version 2.3,“ Network Equipment Security Assurance Scheme, 05.02.2021.

NIST SP 800-218 : NIST, „Special Publication 800-218, Version 1.1,“ National Institute of Standards and Technology, 2.2022.